网易智企·易盾

2025

游戏安全风控指南

2025 Video Games Security Risk Control Guide



扫码获取更多游戏安全咨询

网易智企·易盾

目录

前言

编者按

“Ta”说

2025年游戏安全观察

全球游戏趋势观察 01

全球游戏安全观察 02

中国游戏安全观察 04

2025年网易易盾游戏安全指南

游戏安全概述 06

游戏环境风险 08

游戏外挂风险 10

游戏经济风险 15

游戏合规风险 21

游戏AI风险 31

游戏营销风险 37

游戏私服风险 40

其他游戏风险 42

不同游戏安全概述 48

2025游戏安全趋势观察

游戏厂商视角 56

游戏服务商视角 58

玩家社区视角 59

2025 游戏安全年度自检指南

自检指南概述 62

自检指南评价体系 62

2025 游戏安全大事记

支持单位

关于网易易盾

前言

随着互联网技术的不断进步，游戏行业已成为全球范围内最具活力和发展潜力的领域之一。然而，游戏作弊、内容合规、隐私合规、未成年治理等问题也随之浮现，这些问题不仅威胁到玩家的游戏体验，也可能直接或间接导致游戏经济体系失衡，甚至对游戏厂商带来直接的经济损失。

我们深知，游戏安全需要游戏公司、游戏安全服务厂商、社会等共同的努力，才能够真正打造一个清明、绿色、公平的游戏竞技和体验环境。

网易智企旗下易盾业务作为业内领先的游戏风控解决方案提供商，围绕游戏反作弊、隐私合规、黑灰产治理等积累了丰富的实战经验，我们希望以报告的形式全方位展现2025年各类游戏风险问题。
《2025游戏安全风控指南》详细介绍了当前全球主流的游戏风险问题、国内游戏安全风险问题进行拆解和解读，同时新增渠道反作弊实践指南，游戏AI风险治理指南，为游戏假量问题、AI风控问题提供借鉴和参考。

版权声明

《2025游戏安全风控指南》中的数据均来自于公开的资料与相关数据库，网易智企对相关信息的准确性、完整性或者可靠性尽可能准确但不做任何保证；

《报告》中的检测数据均来自于易盾风控研究院与黑产研究院，对于未注明来源进行引用、篡改或其他侵犯网易易盾著作权的行为，网易易盾将保留追究法律责任的权利。

编者按

在数字娱乐产业的磅礴浪潮中，易盾作为国内领先的专业级游戏安全服务厂商，始终是这场技术革新的重要见证者与坚实守护者。

易盾亲历了游戏生态从经典的 Windows 客户端到如今移动互联时代的全方位、高并发、强对抗的演进历程。这份历程，不仅是技术的迭代，更是网易二十余年的游戏安全技术的深度沉淀与积累。

在服务了上千款公司内外的游戏应用，易盾总结和积累了大量的游戏安全对抗技术，并会在每年发布游戏安全的白皮书，这份报告凝聚了易盾对过去一年游戏安全对抗的深度总结与系统提炼，为游戏从业者提供一个全局的安全风险概览，以及针对安全风险的一些处置建议、游戏安全运营的解决方案。

在《2025游戏安全风控指南》中，您将获得（以下内容根据报告最终目录进行调整）：

1. 全局安全风险概览：对当前游戏外挂、黑产攻击、内容违规等核心安全威胁的最新技术趋势与演变路径进行详尽分析；
2. 实战对抗技术精要：揭示易盾多年积累的攻防策略；
3. 运营与处置建议：针对不同平台和类型的安全风险。

安全无止境，对抗亦永恒。希望这份白皮书能成为每一位游戏开发者、运营者和安全架构师手中的导航灯与战术手册，以清晰的洞察，共筑一个公平、健康、可持续发展的游戏生态。

——卓辉 网易智企 游戏安全负责人

“Ta说” 专家推荐语

游戏安全是娱乐体验的基石，更是平台对每一位用户的责任担当，KK深耕电竞与UGC游戏内容创作，始终将安全置于运营核心，以极致敬畏之心筑牢用户信任防线。
我们深知，游戏安全已从单一防护升级为全链路治理工程，唯有坚守责任底线、完善治理机制，才能为玩家营造安心的娱乐空间，期待这份《指南》凝聚行业共识，推动游戏安全生态实现更高质量的可持续发展。

kk 运营团队

对于《倩女幽魂》这类承载千万玩家情感与心血的国风网游，安全从来不止于账号与虚拟财产的守护，更是维系江湖公平秩序、守护玩家情感联结的核心根基，我们以极致重视守护每一份江湖情怀。
游戏生态的安全稳定是玩家愿意长久停留、投入心血的前提，外挂黑产、交易欺诈等行为不仅破坏公平，更会消解游戏的情感价值。《倩女幽魂》通过安全宣导、便捷举报渠道搭建，让安全理念深入人心。
我们始终坚信，唯有将安全意识前置到运营全流程，把治理重心放在维护玩家核心利益上，才能守住游戏生态的初心。

《倩女幽魂》开发组

"游戏安全就如同铠甲一般,守护着玩家,维持游戏环境的秩序。我们是这场冒险中的铸甲师,不断的提升,为玩家提供更全面的保护,与玩家一起搭建起更加坚实、健康、安全的游戏世界堡垒。"

紫龙游戏 KK 安全团队

"游戏黑灰产工作室不仅破坏了游戏内的经济生态平衡,同时也影响了玩家正常获取资源的公平性。易盾通过技术监测游戏规则的执行，为我们《宿命回响》《灌篮高手》《航海王启航》等游戏在对抗黑灰产工作室作弊行为中提供了极大的帮助,从而营造一个公平、健康的游戏环境，让玩家能够享受到纯粹的游戏乐趣。"

DENA 陈永华DeNA中国游戏技术总监

"这几年非常感谢易盾技术团队和业务团队的辛勤工作和不懈支持。易盾技术团队开发的加固产品、反外挂措施以及风控产品不仅覆盖面广，兼容性强，而且在稳定性上也有出色的表现，这些都得到了我们趣加项目同事的高度认可和赞赏。
在提供这些高品质的技术解决方案的同时,易盾团队也提供了无微不至的支持。专业的技术服务保证了我们的业务流畅运行，同时也帮助我们在市场中建立了良好的声誉。易盾团队对于风险预防和安全保障的专业知识,使我们能够有效地防范各种安全威胁,确保了用户的安全和公司的利益。
我们期待与易盾团队继续保持紧密合作。为用户提供更为安全、稳定的服务。"

FunPlus 游戏安全团队

"《战意》一直将玩家的游戏体验放在首位,重视玩家反馈、优化玩家体验。特别是在游戏公平性，我们的运营团队本着绝不姑息在游戏中使用外挂、脚本等第三方非法软件玩家的原则，第时间对扰乱游戏环境的相关玩家进行了封号处理。打造公平、健康、绿色的游戏对战环境是我们对玩家的首要承诺。"

《战意》运营团队

公平竞技是《全明星》的绝对生命线，更是维系玩家信任、支撑平台长远发展的核心底色，我们始终将安全理念融入产品研发与运营的每一处细节。
公平与否直接决定玩家体验的成败，任何违规作弊行为都会对竞技生态造成不可逆的伤害。因此，我们通过多样化方式从源头杜绝违规风险，让每一位玩家都能在纯粹的对抗中感受竞技魅力。游戏安全的本质，是责任与初心的坚守，是对玩家需求的深刻回应。

《全明星》开发组

"未来,借助AI大模型能力,游戏内容审核将更加智能化,不良内容过滤更为有效,从而更好地维护游戏生态环境。"

YOOZOO游族 贾彦龙游族网络大数据负责人

01

游戏运营安全观察



当前全球游戏运营安全正遭遇技术化、差异化风险与合规压力的双重挑战，同时，AI 加持的作弊手段正在成为业内最为核心的威胁之一，这类风险以隐蔽模拟真实操作的方式规避传统检测，配合 VPN 通道、高端定制挂等技术，给游戏公平性带来极大冲击，比如全国首例"AI外挂"案。

此外，不同游戏品类面临的风险差异显著，RPG 游戏易遭模拟点击脚本侵袭、FPS 游戏中修改器作弊占比达59%，SLG游戏面临跨端脚本隐患，小游戏则受模拟器刷量与 DDoS 攻击困扰。黑灰产还通过云手机挂机刷金破坏游戏经济，大模型生成的违规内容与跨平台诈骗则加剧内容安全危机。

全球游戏趋势观察

根据 Newzoo 的相关数据，2025 年全球游戏市场预计将达到 1888-1890 亿美元，同比增长 3.4%，表明整个游戏行业正逐步回归稳定增长轨道。

各平台发展态势分化

- **主机游戏增长显著**：2025 年主机游戏市场预计将实现强劲反弹，收入达到 459 亿美元，同比增长 5.5%，成为所有平台中增速最快的细分市场。原因主要在于新主机周期的推动作用明显，如 PlayStation 5 和 Xbox Series X|S 供货情况改善，PS5 销量增长，且 2025 年随着 PS5 Pro 的推出和 Switch 2 的上市，主机硬件销售有望进一步增长。此外，独占游戏策略效果显著，订阅服务也成为新的增长点。

- **PC 游戏稳健增长**：PC 游戏市场展现出稳健的增长态势，2024 年预计收入将达到 399 亿美元，同比增长 2.5%。Steam 平台表现强劲，跨平台游戏成为趋势，电竞和在线游戏也持续繁荣。

- **移动游戏增长放缓**：移动游戏继续保持全球游戏市场的主导地位，但增长势头有所放缓。从 20245 年 Q1 至 2025 年 Q1，中重度游戏的出海安装总量下降 43%，而超休闲和休闲游戏安装总量同比增长高达 159% 和 48%。

- **商业模式创新**：“混合变现”模式正在成为主流，截至 2025 年 Q1，结合 IAA 与 IAP 的混合变现占比达 52%，比 2023 年增长 27%，已超过单一变现路径，成为全球游戏开发者的首选商业模型。

- **技术应用深化**：AI 技术在游戏开发和营销中作用显著，可用于辅助游戏设计、关卡生成、剧情创作等，还能实时优化游戏性能，提升玩家体验。在营销方面，AI 有望实现营销全流程自动化，通过智能体联动完成素材生成、投放及优化。此外，VR 和 AR 技术的成熟也为游戏开发带来新的可能性，2025 年 VR/AR 设备出货量预计达 4500 万台，游戏内容适配率提升至 60%。

- **用户行为变化**：全球游戏玩家数量持续增长，2025 年预计达到 35.8-36 亿，同比增长 4.4%，但增速呈现放缓趋势。付费玩家数量预计达到 16.2 亿，同比增长 4.9%，增速超过玩家总数增长，玩家的付费意愿和能力在提升。

- **区域市场格局变化**：亚太地区仍以 47%-49% 的份额稳居全球游戏市场收入首位，但全球手游格局正在从“亚太一极”迈向“多极共振”。中东和非洲增长最为迅猛，预计 2025 年将实现 7.5% 的增长，拉美市场也展现出强劲的增长潜力，2025 年收入同比增长 6.2%。

全球游戏安全观察

2025年，全球游戏市场规模庞大且持续增长。与此同时，游戏安全事件造成的经济损失正在以惊人的速度增长。

面对日益严峻的安全威胁，游戏安全防护市场呈现出强劲的增长势头。在线游戏安全市场规模从 2025 年的20.7 亿美元增长到 2025 年的23 亿美元，预计到 2032 年将达到51.1 亿美元，年复合增长率为11.91%。

这种增长反映出游戏企业对安全防护的重视程度不断提升，但同时也说明了安全威胁的严重性和复杂性正在快速升级。

1. 亚太地区

关键词：外挂、黑产、内容合规

亚太地区作为全球最大的游戏市场，同时也是安全风险最为集中的地区。包括：中国市场外挂问题和黑产问题日益严重，检测与治理数据2025年创新高；日本和韩国市场相对较为成熟，安全防护水平较高，但是韩国政府在 2025 年推出了游戏产业政策改革，废除了争议性的 GRAC 事前审查制度，改为负面清单式管理，这在一定程度上提升了市场的开放性，但也可能带来新的安全挑战。

2. 北美地区

关键词：勒索、反外挂、诈骗

根据 SOCRadar 的报告显示，2025 年北美地区面临着全球最严重的勒索软件威胁，且该类威胁呈现攻击集中度高、勒索软件猖獗、经济损失巨大等现状，其中北美地区的勒索软件攻击占全球数字勒索活动的62%，创下历史新高。而美国市场的另一个特点是多账户欺诈和奖金滥用问题严重，由于各州法规不同，欺诈者利用州特定游戏促销活动的漏洞，通过创建多个账户来滥用奖金优惠。

3. 欧洲地区

关键词：数据合规、隐私泄露

欧洲地区监管严格但攻击频发，欧洲是仅次于北美的第二大目标地区，欧洲组织占专用泄露网站（DLS）上命名实体的近22%。其中，英国、德国、意大利、法国和西班牙受到的攻击最为严重。此外，欧盟的 GDPR 合规要求和多个游戏管理机构需要强大的数据隐私和道德 AI 实践。

同时，欧盟拟议的《数字公平法案》可能将“游戏内货币”视为具有金融属性的资产，纳入金融交易监管范围，这将给游戏企业带来巨大的合规压力。

4. 拉美地区

关键词：诈骗、深度伪造

拉美地区作为新兴游戏市场，特别受到中国游戏企业青睐，自然成为游戏安全风险的新兴热点，特别是巴西和秘鲁：主要表现在欺诈增长迅猛和深度伪造问题突出，此类问题主要表现在博彩类游戏中。

5. 中东非洲

关键词：未成年人保护、隐私合规

当然，中东和非洲作为另一个快速增长的新兴市场，近年来游戏玩家增速迅猛，而由此带来的年龄保护、反成瘾保障措施和数据隐私合规等问题已经被提上政府日程。

中国游戏安全观察

作为全球游戏产业的核心市场，2025 年中国游戏市场规模占全球比重超 30%，手游用户规模突破 6.8 亿人，端游与云游戏用户量同步攀升。

但伴随产业高速发展，安全风险呈现 “本土化加剧、技术化升级、链条化蔓延” 的显著特征。同时，高增长与强对抗并存。

1. 游戏外挂作弊

关键词：AI 定制外挂、射击类集中、安全系统攻击

根据网易易盾2025年检测数据显示，移动游戏定制化外挂占比 86.62%，AI 生成 “类人行为脚本” 使作弊检测误判率升至 37%；PC 端 81.9% 外挂集中于射击类游戏（如《绝地求生》），头部产品日均外挂检出率超 12 万次；5.44% 外挂针对游戏安全系统。

2. 黑产经济

关键词：千亿产业链、本土化变现、跨境操作

目前，国内游戏黑产形成了年产值超 200 亿元的完整产业链，中等刷金工作室可操控 5000 台以上云设备，某仙侠 MMO 游戏因刷金 3 个月内金价从 4 元 / 万跌至 3 元；黑产通过抖音直播间、微信社群等本土化渠道变现占比 72%，首充号、代练开挂订单量同比 + 89%；90% 跨境黑产团伙采用 “境内接单、境外算力” 模式，使用东南亚云服务器规避监测。

3. 内容安全

关键词：违规内容泛滥、DIY 玩法风险、本土化诈骗链路

辱骂信息、不良广告、违规内容构成了游戏内容安全三大隐患，比如沙盒类游戏用户自建违规场景、智能NPC 引导性的不良对话、AI 生成变种广告逃避检测、游戏内诱导进群实施交易诈骗等。

4. 数据安全

关键词：泄露事件频发、合规成本攀升、未成年人信息风险

2025 年国内游戏企业数据泄露事件超 60 起，某头部手游厂商因第三方 SDK 漏洞泄露 1200 万用户手机号；企业数据安全合规投入平均增长 35%，中小厂商因合规不足被罚案例同比 增长62%，单案最高罚款 500 万元；16% 数据泄露事件涉及未成年信息，某教育类游戏曾泄露 23 万条学生信息引发专项核查。

5. Web3 游戏

关键词：合约漏洞损失、本土化钓鱼

国内 Web3 游戏试点阶段因智能合约漏洞损失超 3.2 亿元（占全球同类损失 13%），某国产链游因重入攻击单日损失 5800 万元；利用 “元宇宙房产”“数字藏品空投” 的本土化钓鱼占 Web3 游戏诈骗总量 68%，受害者以 30 岁以下玩家为主。

02

游戏安全指南



游戏运营安全定义

游戏运营安全（Game Operations Security）是指在网络游戏的全生命周期（研发、测试、上线、长线运营）中，游戏厂商通过技术手段、风控策略、人工审核及合规机制，构建的一套综合防御体系。

其核心目的是对抗破坏游戏平衡、侵害厂商利益、违反法律法规及损害玩家体验的恶意行为，从而保障游戏的稳定运行、商业收益、品牌声誉及合规性。

游戏运营安全的关键在于用户体验和安全防御之间寻找动态平衡，以确保持续产生商业价值。



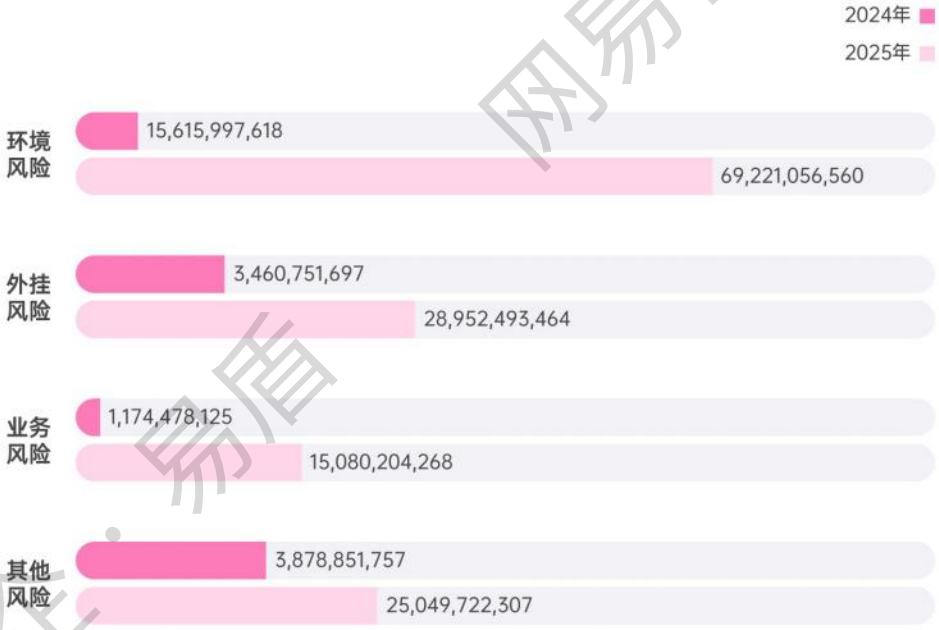
——游戏运营安全全景图——

游戏运营安全数据概览

据网易易盾游戏安全数据显示

2025年全年，游戏总体风险对抗激烈并呈现出上升态势，易盾全年累计检测安全风险138,303,476,599次，同比增长571.36%，其中环境风险威胁较大，检测69,221,056,560次，占整个检测安全风险类型的50%，同比增长443.27%。外挂危险持续增长，2025年全年累计检测28,952,493,464次，占比20.93%，同比增长836.59%。

此外，本年度业务风险监检测，全年累计检测15,080,204,268次，占游戏安全风险总体的10.90%，同比增长1283.99%。其他风险呈现出指数级增长态势，累计检测25,049,722,307次，占比18.11%，同比增长645.80%。



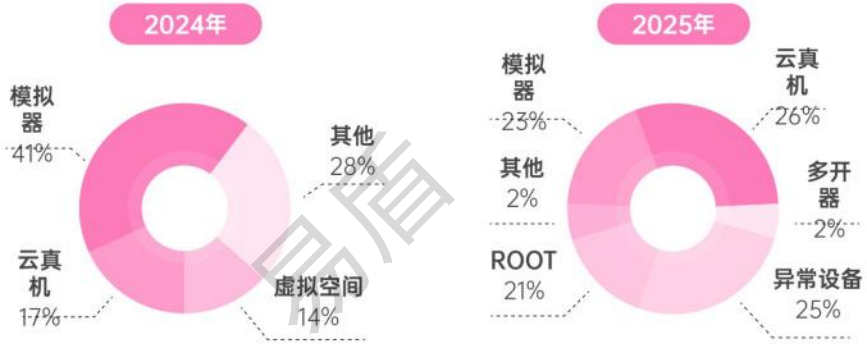
游戏总体风险对比

游戏环境风险

游戏环境风险主要指通过对运行环境进行修改进而影响游戏进程，如模拟器、云真机、ROOT、越狱、改机设备（改机、刷机、定制ROM）、虚拟机等。

2025年，网易易盾围绕游戏风险特征，通过定量分析手段，检测出前四大标签异常设备（25.56%）、云真机（24.60%）、模拟器（22.60%）、ROOT（20.73%）合计占比超过93%，是该风险类型的核心组成部分。

2024-2025 游戏环境风险问题占比对比



参考对比图

游戏环境风险特点

游戏环境风险主要体现在ROOT/越狱环境和低成本设备环境两个方面：

ROOT/越狱环境

ROOT/越狱环境是外挂运行的温床，通过获取系统最高权限，作弊工具可以直接修改游戏内存数据、劫持系统服务实现透视自瞄等功能，并能隐藏自身特征躲避安全检测。这类环境为外挂提供了突破游戏沙箱限制的底层能力，使其能够深度干预游戏运行逻辑。

低成本设备环境

低成本设备环境是黑产批量作业的基础设施，工作室为提高ROI采用主板机、模拟器、云手机等廉价设备进行大规模自动化搬砖。这类设备成本低、易扩展，支持批量部署和脚本化操作，能够7×24小时不间断运行，对游戏经济系统和正常玩家体验造成严重冲击。两类环境往往相互结合，形成"ROOT环境+低成本设备+自动化脚本"的完整黑产链条。

游戏环境风险治理难点

目前，游戏环境风险治理主要面临正常与恶意行为边界模糊、正常与恶意行为边界模糊和正常与恶意行为边界模糊三大核心挑战：

正常与恶意行为边界模糊

大量正常玩家出于系统定制、性能优化等需求使用ROOT、模拟器、云手机等环境，这些环境与黑产使用的技术手段高度重叠，导致难以通过环境特征直接区分正常玩家与作弊者，误判风险极高。

权限对抗的天然劣势

在ROOT/越狱环境下，外挂拥有系统最高权限，可以任意篡改内存、劫持系统调用、伪造设备信息，而游戏反作弊系统运行在受限的应用层权限，形成完全不对等的攻防态势，检测准确性和覆盖面都受到根本性制约。

不可信环境的数据失真

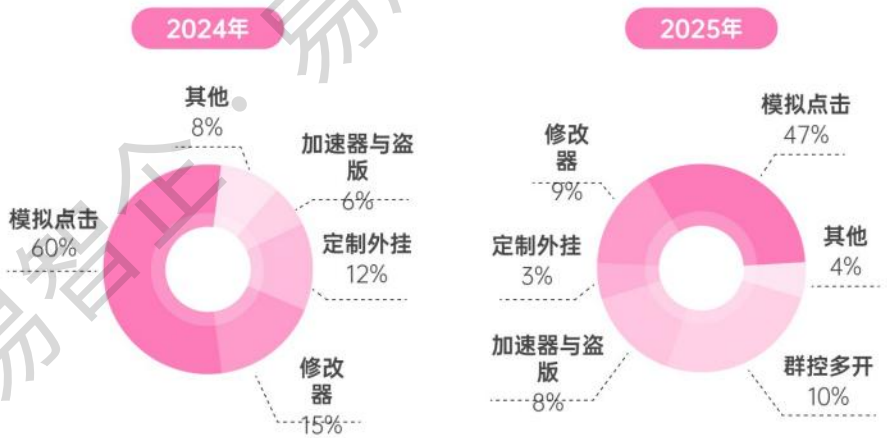
当系统环境本身不可信时，游戏采集的所有数据（设备指纹、行为日志、内存状态）都可能被伪造或篡改，传统基于数据分析的风控手段失效，需要依赖云端行为建模、多维交叉验证等间接方式识别风险，但这又会大幅提高治理成本和响应延迟。

游戏外挂风险

游戏外挂问题一般指，游戏玩家为了取得胜利、获取更大的竞争优势，在游戏内使用脚本、外挂等辅助手段，从而破坏游戏对战平衡，获取非"正常"胜利的手段。

常见游戏外挂主要包括：包括修改器、模拟点击、恶意应用、加速器、盗版等。
2025年，易盾全年监测外挂风险中模拟点击占比高达60%、修改器占比15%、定制外挂占比11%、加速器与盗版合计占比为6%，其他风险占比8%

2024-2025 游戏外挂风险问题占比对比



—— 参考对比图——

客户端游戏外挂

目前，客户端游戏常见外挂包括DMA硬件外挂、AI视觉外挂、内核级外挂、跨端外挂等主要类型：

DMA硬件外挂

攻击者使用特制的PCIe硬件（如DMA卡）直接读取物理内存，完全绕过监控机制，使得运行在Ring0（内核态）/Ring3（用户态）层的反作弊软件无法检测到内存读取行为，实现"物理级"透视。这类外挂通过硬件总线直接访问内存，对游戏进程完全无感知，且成本随硬件降价逐渐普及。

AI视觉外挂

攻击者利用计算机视觉和深度学习技术实时识别屏幕画面中的敌人轮廓、任务目标等信息，通过模拟鼠标/键盘输入实现自瞄、自动寻路等功能。这种方式不读取游戏内存、不注入代码、不修改游戏文件，纯粹基于图像识别和外设模拟，极难被传统的内存扫描、代码完整性检测等手段发现，且随着AI算法开源化，制作门槛持续降低。

内核级外挂

此类外挂驱动运行在Ring0层，与反作弊系统进行内核态权限争夺。通过加载恶意驱动程序，不仅能实现内存读写、函数Hook、游戏逻辑修改等核心外挂功能，还能主动对抗反作弊检测（如禁用反作弊驱动、隐藏进程/模块、伪造系统调用返回值），实现自身隐藏和持久化运行。

跨端外挂

此类外挂工具运行在物理机（宿主机）上，游戏运行在虚拟机/云手机等隔离环境中。攻击者通过虚拟化层的内存映射机制读取虚拟机内存，或通过屏幕采集+图像识别方式获取游戏状态，再通过虚拟输入设备注入操作指令。由于外挂与游戏运行在不同操作系统实例中，端侧反作弊系统完全失效，只能依赖行为分析检测。

移动端游戏外挂

端游戏常见外挂包括内核级外挂、群控/脚本挂、破解版/重打包等类型：

内核级外挂

通过ROOT/越狱获取系统最高权限后，加载恶意内核模块，实现对游戏进程的内存读写、函数劫持、系统调用拦截等操作，通过内核模块完成外挂功能，并隐藏外挂信息、绕过安全检测等。

群控/脚本挂

使用自动化脚本或群控系统实现批量挂机、自动任务、资源搬砖等功能。脚本通过模拟点击、滑动等操作执行重复性任务，群控系统则通过OTG/WiFi同步控制多设备，实现工作室规模化作业。这类外挂成本低、部署快，是移动游戏黑产的主流手段。

破解版/重打包

攻击者对游戏APK/IPA进行逆向分析后，修改游戏逻辑（如去除支付验证、修改道具掉落概率）或内置外挂功能（如透视、加速），重新签名打包后通过第三方渠道分发。用户下载运行的是被篡改的游戏客户端，从源头上绕过了正版客户端的安全机制。

小游戏外挂

小游戏常见外挂包括协议破解、内存修改和Hook挂等类型：

协议破解

通过抓包分析小游戏与服务器的通信协议，伪造或重放游戏请求实现刷分、刷道具等作弊行为。由于小游戏通常使用HTTP/WebSocket等明文或弱加密协议，且客户端JavaScript代码可直接审查，协议破解门槛极低。攻击者可编写自动化脚本批量发送伪造请求，绕过客户端逻辑直接与服务器交互。

内存修改

可直接使用CE、GG等常规内存修改工具，对游戏中的关键内存变量（如金币数量、倒计时、游戏状态）进行修改。

Hook挂

攻击者对游戏包进行逆向分析后，通过对小游戏平台进行注入，然后动态修改游戏的逻辑，最终达到作弊的目的，由于小游戏权限现在，难以发现平台注入等异常情况

游戏外挂特点

当前游戏外挂已形成三大发展趋势，即定制化、二是硬件化、产业链闭环特点，具体包括：

- **定制化**：外挂制作从通用工具向特定游戏深度定制演进，针对单一游戏开发专属功能模块（如某FPS游戏的弹道预测、某RPG游戏的自动副本流程），通过精准匹配游戏版本、优化检测对抗策略，显著提升隐蔽性和用户体验。

- **硬件化**:从软件外挂向硬件外挂升级，代表性产品包括DMA内存读取卡、物理鼠标宏设备、移动端的HID插件。硬件外挂通过物理层面绕过操作系统和反作弊系统的监控，检测难度呈指数级上升，且随着硬件成本下降，使用门槛逐渐降低。

- **产业链闭环**：形成"外挂开发-卡密分发-售后服务-代理销售"的完整黑产链条。上游提供外挂框架和更新维护，中游搭建卡密系统和支付渠道，下游发展多级代理和客服团队。部分产业链还整合了账号交易、代练服务、游戏币交易等环节，形成生态闭环，单款热门游戏外挂年产值可达数千万元。

游戏外挂治理难点

检测与兼容的平衡

强力的反外挂策略（如强力扫描、强力 Hook）容易导致误封正常玩家或引发游戏崩溃、卡顿，影响用户体验。

权限层面的天然劣势

外挂可以运行在Ring0甚至更底层（如BIOS/UEFI固件、虚拟化层Hypervisor），而反作弊系统通常只能运行在Ring0或Ring3，在权限等级上处于被动防守位置。即使双方都在Ring0层，外挂可以通过抢先加载、禁用反作弊驱动等手段占据主动。

技术迭代的攻防循环

反作弊升级检测手段→外挂更新对抗方法→反作弊再升级，形成永无止境的军备竞赛。外挂开发者只需找到一个突破口即可绕过检测，而反作弊需要防御所有可能的攻击面，防守成本远高于攻击成本。

法律取证门槛高

需要证明外挂制作、传播、使用与游戏损失之间的因果关系，这涉及电子数据固化、鉴定报告出具、损失金额评估等复杂流程。跨境外挂（服务器在境外）、匿名交易（使用加密货币）更增加了调查难度。

产业链隐蔽性

外挂销售采用暗网交易、即时通讯私密群组、动态域名等方式规避监管，资金流通过多层洗钱和虚拟货币转账，难以追溯到幕后组织者。部分外挂团队甚至注册为"游戏辅助工具公司"，以合法企业身份掩护非法业务。

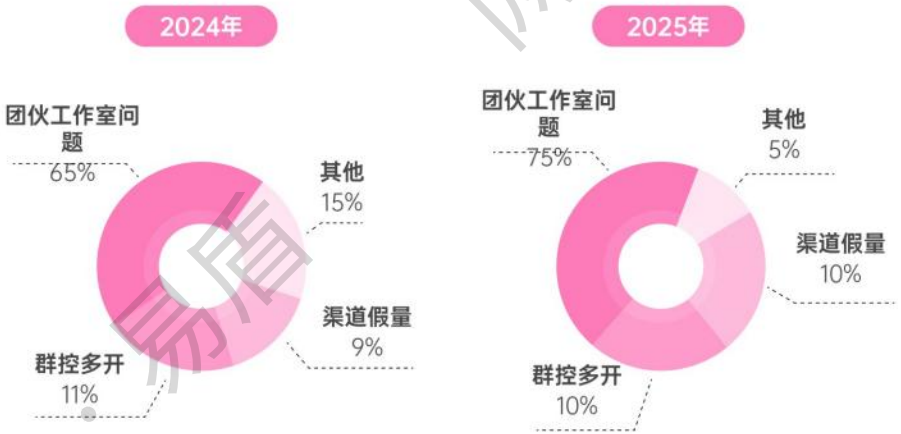
游戏经济风险

游戏经济风险，主要指玩家及工作室商人利用自动化脚本低成本获取游戏内高价值的游戏币、道具、装备、点券等，从而破坏游戏内原有交易系统的价格体系和供求关系，以此导致游戏产生坏账、资源侵占、货币系统崩盘等。

常见的影响游戏经济问题的主要包括：打金工作室、脚本工作室、资源囤积号、渠道拉人号等。

2025年，网易易盾通过智能风控产品的实时风险感知与智能模型分析，检测出团伙工作室问题最为严重，占比高达75%，群控多开占比为11%、渠道假量问题占比9%，其他问提占比5%。

2024-2025 游戏经济风险问题占比对比



—— 参考对比图——

不同类型的危害

游戏经济风险带来的危害主要包括以下几点：

资源侵占与产出失衡

工作室自动化脚本7x24小时不间断产出，破坏游戏设计的资源消耗循环，导致材料、货币急速贬值，正常玩家辛苦劳动成果价值缩水。

交易市场操纵与价格崩坏

利用扫货脚本垄断稀缺物资，低买高卖；或大量抛售黑产金币，冲击市场价格体系，使自由交易市场名存实亡。

货币系统冲击与坏账积累

黑产游戏币的泛滥实质是超发，稀释全体玩家财富，并可能通过非法渠道变现，造成游戏内经济体系的"坏账"与真实世界金融风险。

玩家体验损害与流失风险

正常玩家在资源争夺（如BOSS、采集点）、PVP环境（被脚本号干扰）、经济参与感（无法公平交易）上全面受损，导致核心玩家社群萎缩。

安全风险外溢与品牌损伤

工作室常伴随账号盗取、诈骗、虚假广告等违法行为，破坏游戏社区氛围，严重损害游戏品牌声誉与长期价值。

游戏经济安全攻防战

游戏经济安全的对抗，是一场与工作室及外挂技术持续博弈、动态升级的"军备竞赛"。这一过程已从早期的单一特征封禁，演进至基于大数据与人工智能的体系化、智能化纵深防御。以某头部MMO游戏的对抗全记录为例，清晰地揭示了这场攻防战的四个关键阶段，体现了防御策略从被动响应到主动智能围剿的跃迁。

第一阶段：脚本泛滥与基础规则对抗（单设备多开）

游戏上线初期，工作室利用多开器在单台电脑上批量开启客户端，进行同步刷资源等操作，技术门槛低、见效快，直接冲击游戏经济。此阶段，防御主要依靠客户端基础防护，通过精准监测多开器进程、内存注入痕迹、窗口句柄复用等特征，建立特征库进行实时识别与拦截。这属于"亡羊补牢"式的规则对抗，有效遏制了最初的规模化违规，但也拉开了技术升级的序幕。

第二阶段：特征深化与团伙关联挖掘（多设备同步）

当单设备多开被阻断，工作室转向使用同步器控制多台物理电脑，每台只运行一个客户端，以规避单设备检测。防御随之进入聚合检测与纵深防御阶段。风控策略从单点突破升级为关系网络分析，通过IP聚合（分析同一IP段下大量账号的登录规律与行为同步性）与设备指纹聚合（识别多台设备在硬件批次、系统环境上的同质化关联），穿透独立设备的伪装，实现对工作室集群的精准定位与打击。

第三阶段：环境伪装识别与精准穿透（虚拟机/云手机群控）

面对设备集群的暴露风险，工作室开始采用虚拟机或云手机技术，为每个账号提供独立的虚拟硬件环境，并将中控脚本部署在宿主机，实现隐蔽的"一对多"远程操控。对抗重点转向虚拟化环境识别。通过深入分析虚拟硬件标识（如网卡MAC段、磁盘型号）、系统底层虚拟化痕迹（VMM进程、特定驱动）、以及多个虚拟实例间CPU/内存资源的同步调用曲线，建立虚拟环境特征库，实现对虚拟机、云手机等高隐蔽性载体的精准识别与标签化管理。

第四阶段：AI智能建模与体系化围剿（硬件同步+AI拟真脚本）

在虚拟环境也被识别后，工作室的对抗手段进一步融合，演变为结合硬件同步器、分布式云环境与高度拟人化AI脚本的复杂体系。其操作行为更接近真人，且跨终端、跨网络，传统规则难以应对。此阶段标志着防御进入"AI智能建模"为核心的新纪元。防御体系通过多种AI模型构建多维感知网络。

交易图谱模型：针对工作室"产金-洗钱-变现"的完整链条，构建基于图神经网络的交易关系图谱。该模型分析游戏内货币与高价值道具的转移链路、转移频率、交易对手关系网络及交易时间模式，能精准识别出底层的产金号（资源产出源头）、中层的中转号（混淆交易）以及顶层的金主号（资金归集与变现出口），实现"打蛇打七寸"，瓦解其经济循环。

账号移动轨迹检测模型：针对使用虚拟机、云手机进行群控或远程控制的工作室，其操控的成百上千账号在移动路径上会呈现高度的时空同步性与轨迹相似性。该模型通过分析账号的移动坐标序列、转向点、停留时间等，利用聚类算法识别出移动模式高度一致的批量账号集群，即使它们分布在不同的虚拟环境或IP下，也能有效穿透伪装，锁定群控工作室。

任务行为链AI检测模型：这是对抗高阶自动化脚本的核心。工作室为对抗IP与设备检测，会采用分布式网络、不断更换设备标识。此模型不依赖单一静态特征，而是聚焦于行为序列的相似性。它通过自然语言处理（NLP）与时间序列分析技术，将玩家在一段时间窗口内完成的任务、副本、活动等行为编码为"行为链"。对于使用同一套AI模拟脚本或中控指令的账号群，其行为链在顺序、时间间隔、操作节点上会呈现极高的相似度。模型能以此发现并圈定隐蔽的批量操作群体，有效打击"拟人化"脚本。

AI模拟点击识别：作为行为检测的补充，直接针对脚本的输入层进行监测，识别非人类操作的鼠标移动轨迹、点击间隔的机器规律。

团伙标签生成：综合上述模型输出，自动生成团伙标签，实现从"打击单个账号"到"连根拔起整个作案网络"的升华。

这一阶段的对抗，是数据、算法与算力的综合比拼，旨在实现从"事后封禁"到"事中干预"乃至"事前预警"的转变。

未来展望：持续进化与主动免疫

攻防对抗永无止境。未来的外挂可能深度结合强化学习，实现自适应绕过。相应的，防御体系将向"持续学习的主动免疫系统"发展，深度融合客户端加固、实时流计算、联邦学习与博弈论，并与游戏经济系统设计形成联动调控，最终构建一个技术、运营、生态三位一体的全域风控与健康运营体系。这场较量，推动着游戏安全技术不断向前突破。

游戏经济风险特点

游戏经济风险呈现出鲜明的复合型特征：

风险主体已形成高度组织化、产业化的黑色链条，从外挂开发、账号供应到资源生产与线下变现一体运作，并不断采用新技术隐蔽行踪，使得对抗具有极强的隐蔽性和持续性。

攻防本质是技术驱动的快速迭代战，攻击方已从简单宏命令升级至人工智能模拟操作，迫使防御体系必须从规则引擎跃迁至AI模型，双方在极短的周期内竞相升级，技术门槛居高不下。

游戏经济安全危害具有显著的滞后性与系统性，经济系统的崩坏往往在资源长期失衡抵达临界点后突然爆发，进而冲击几乎所有玩法与全体玩家体验，治理修复成本高昂；最后，风险与游戏类型及经济设计强相关，MMORPG、开放世界等经济系统复杂的游戏尤为突出，若交易自由度过高或资源回收机制存在缺陷，将极大助长风险蔓延。

游戏经济风险治理难点

“误判”与“漏判”的平衡难题

严厉策略易伤及正常多开玩家或搬砖党，宽松策略则无法遏制工作室，需要在安全与体验间找到最佳平衡点。

技术对抗成本高昂

尤其是面对定制化、不断变种的外挂，需要持续投入研发资源进行AI模型训练与特征库更新，对中小团队压力巨大。

作弊成本低，防御成本高

工作室批量注册账号成本极低，而防御方需要为每个账号的分析付出计算和存储成本，在资源消耗上不对称。

法律与取证的现实障碍

对游戏内虚拟财产的法律界定尚不完善，跨地域、跨平台追踪和打击黑色产业链存在现实困难。

需要跨部门协同与数据孤岛

有效治理需要技术、运营、市场、客服乃至法务部门紧密协同，且数据若能打通，但实践中常存在壁垒。

易盾建议

建设智能化、平台化的风控中台：强化客户端SDK对设备异常信息的识别检测能力，同时整合交易图谱、行为链分析、轨迹聚类等AI模型，形成可动态配置、持续学习的智能风控平台，提升风险自动识别与处置效率。

实施“数据驱动”的梯度治理体系：

- 实时拦截层：对明确恶意特征（如虚拟机多开、已知外挂进程）实时阻断。
- 智能监控层：利用AI模型对可疑账号进行行为限制（如产出衰减、交易冷却）、资源标记追踪。
- 深度打击层：基于团伙关系图谱，实施“连坐”封禁，并定期组织专项打击行动，公示成果以威慑灰色产业。

深化运营经济机制设计：

- 引入动态调控机制，如根据市场物价波动自动调节副本产出、交易税率。
- 设计更多账号绑定、时间绑定或角色绑定的高价值道具，增加黑产资源流转难度。
- 合理设置资源回收出口（如装备强化、NPC商店回收），维持货币与资源的健康循环。

构建“开发者-安全团队-玩家”共治生态：

- 向玩家开放透明的举报反馈渠道，并建立举报奖励机制。
- 定期发布安全公告，向玩家普及风险，展示治理决心与成果。

游戏合规风险

游戏合规风险，一般是指游戏内的内容合规、隐私合规和未成年人保护，该类风险主要不符合国家法律规定、社会公俗良德约束等问题。2024-2025 年中国监管对游戏行业的合规要求仍然呈加强与精细化并行的态势，核心关注点集中在：

（1）未成年人保护与防沉迷（更细化的"未成年人适配/分级/提示"规则）
（2）内容导向与"有害信息"识别（更严格的内容审查与分类要求）
（3）个人信息收集使用合规与跨境流转合规（集中整治违法收集/过度收集）

由此可见，监管已由宣传与指导逐步转为制度性、标准化与专项执法行动。

2025监管要点

- **中央网信办持续组织专项整治（"清朗"专项、暑期未成年人网络环境整治）**：2025 年中央网信办部署了"清朗·2025 年暑期未成年人网络环境整治"专项行动，明确要重点检查未成年人模式使用、内容建设问题、儿童智能设备与 AI 功能对未成年人的影响等。监管具备全国性协调、跨部门执法的能力。

- **套规则与征求意见走向精细化**：网信办会同多部门在 2025 年持续发布（或征求）配套办法，例如"可能影响未成年人身心健康的信息分类办法（征求意见稿）"和针对"对未成年人具有显著影响的平台认定办法（征求意见稿）"，说明监管正在把『影响范围/分类标准/提示机制』落到可操作层级。

- **人信息与隐私合规被多部门同步推进**：市场监管、网信、工信等部门在 2025 年继续开展个人信息保护系列专项行动，重点打击违法违规收集使用个人信息、滥用同意、过度收集等典型问题。个人信息保护相关行政检查与处罚力度上升。

- **司法/仲裁/判例与行政处罚已开始落地**：有司法判例与执法通报显示：如实名认证不严导致的未成年人充值纠纷、企业需部分退款；以及针对规避防沉迷与代练/租售账号等灰色行为的查处建议正被强调。监管不再只是口头指导，而是进入"责任追究 + 退费/罚款 + 行政通报"阶段。

合规风险及危害

- 内容安全监管核心从"静态审核"到"动态行为治理"，深化场景化治理，从"内容审核"扩展到"全链路内容治理"。

- 监管已不再只关注文本、图片、聊天，而是涵盖：游戏社交（聊天、弹幕、公会、留言板），用户生成内容（UGC / 自定义形象 / 地图编辑器），AI 生成内容（AIGC 关卡/剧情/头像），游戏直播、短视频扩散链路，游戏经济体系中的灰产传播（外挂、代练、私服宣传）。

- 个人信息合规场景化治理进一步深化，从"App 合规"扩展到 App、SDK、智能终端、线下场景、人脸识别、犯罪链条全链路。部门联动常态化：网信办（牵头）+ 工信部（App 与通信终端）+ 公安部（违法犯罪）+ 市监总局（消费场景）形成"多部门合力"的监管格局。合规从"形式合规"迈向"实质合规"：不仅看是否有规则，还关注"是否必要"、"是否最小化"、"是否提示充分"，更强调用户的真实可选择性。技术化、专业化趋势加强：穿戴设备、高精度采集、云端计算等成为重点，意味着监管不再停留在传统 App，而是延伸到所有智能设备。

- 未成年人保护从单点防沉迷到多维度未成年人保护的"综合未保体系"，防沉迷强监管逐渐向完整的"未成年人数字保护体系"延伸，包括：游戏时长控制，游戏消费限制，不良内容过滤，社交与陌生人互动管控，游戏直播观看限制，算法推荐限制，广告和营销规范，隐私保护"最小必要"原则。

- 随着沙盒游戏、派对游戏等开放世界游戏的发展，用户创作内容的门槛持续降低，玩家可以在更高自由度的环境中进行捏脸、建造、脚本编写、地图编辑、剧情生成等活动。随之而来的是大量玩家自主创作的场景性违规内容，需要引起游戏厂商重点关注。此类问题轻者影响玩家体验，重者则会形成大规模传播，最终可能触发监管介入，甚至导致游戏停服的严重风险。

- 在这些开放能力中，游戏角色主要指由玩家自定义的服装、昵称、面部表情（捏脸类）、动作摆拍等，容易出现擦边、暴露、敏感人物模仿等问题；游戏场景主要针对由玩家自由建造的游戏地图和建筑物，常见违规包括敏感符号摆放、恶搞宗教/政治建筑物等；游戏频道涵盖世界频道、团队频道、队伍频道等实时互动场景，违规风险在于用户发送的文字、图片、表情、语音内容中可能夹带色情、辱骂、广告、诈骗等；游戏 NPC尤其是具备 AIGC 内容生成能力的 NPC，更易被玩家诱导输出不当内容；而游戏社区则包含头像、昵称、个性签名、动态及评论区，可能出现传播违规图片、视频、低俗言论和各类灰产引流内容。

MMO / 社交型游戏

MMO 与强社交型游戏由于具备多人同屏、公会组织、自由经济体系、长时间沉浸式互动等特点，是内容安全、隐私安全、未成年人保护中风险最高的游戏类型之一。玩家之间的实时互动极易产生聊天违规、辱骂、低俗图片传播、语音攻击等行为；公会系统可能被组织化灰产利用，用于招募外挂玩家、拉人推广、跨平台引流；虚拟货币体系若缺乏风控，则可能与洗钱、非法交易关联。此类风险一旦外溢，往往引发大规模舆情，轻则渠道整改，重则触发公安与网信部门介入。

竞技类游戏（MOBA / FPS / Battle Royale）

竞技类游戏强对抗、高刺激的特点，决定了其内容安全与账号安全双高风险。高价值账号推动了代练、租号、买卖账号等灰产的繁荣，代练群体会绕过实名认证和未成年人限制；外挂问题长期处于监管重点，相关行为不仅影响游戏公平性，也常与跨境灰产组织相连；实时语音场景中辱骂、攻击性语言、未成年人被诱导等问题频发。若缺乏有效治理，容易导致"社区整体恶化"，进而引发监管与赛事版权方的关注。

卡牌 / 抽卡类 / RPG 数值驱动型游戏

卡牌与抽卡类游戏的核心风险集中在金钱互动与概率机制。抽卡概率不透明、结果呈现夸大、活动结构诱导付费等问题，容易触发市监部门的"诱导消费"、"不当营销"、"未成年消费纠纷"风险；部分游戏存在用词不当的宣传文案、过度强化收益的运营活动，容易被定性为误导性广告。此外，直播间"开箱式抽卡"也逐渐成为监管新关注点。

轻度休闲游戏 / 放置类游戏

休闲类游戏用户基数大、广告投放密集，是广告违规高发领域。常见问题包括广告素材低俗、画面与落地页不符（俗称"虚假广告"）、开屏广告诱导误触、未成年人可直接跳转下载等。由于此类产品对广告变现依赖度高，违规素材一旦被平台巡查命中，可能导致整批广告被封禁、渠道收入骤降，甚至被应用市场下架。

不同游戏形态在用户触点、数据链路、交互强度上差异显著，因此不合规带来的风险也呈现不同特点。整体来看，不合规风险主要体现在 监管处罚、品牌受损、用户流失、业务中断、法律责任 五大方向。

游戏类型	2024年	2025年
MMO / 社交型游戏	多人实时互动、 公会体系、自由聊天、 UGC 丰富	大规模内容违规（黑灰产、色情、诈骗信息）触发平台责任 未成年人社交风险高（陌生人聊天、语音） 公会/交易形成"灰色经济圈"触发公安/网信处罚 虚拟货币体系易与洗钱、代练团伙关联
（MOBA、FPS）竞技类	账号价值高、代练/租号现象普遍	代练、租号关联未成年人绕过防沉迷 高频使用外挂引发公安机关介入 游戏内辱骂、对抗情绪容易形成内容安全风险 赛事内容需符合版权、广告、未成年保护等要求
卡牌类 / 抽卡类	付费频繁、 概率机制明显	抽卡概率不透明引发"诱导消费"监管处罚 未成年人消费纠纷高发 营销文案触及"误导性宣传" 运营活动存在诱导登录、诱导付费风险
放置类 / 轻度休闲类	下载量大、 广告投放密集	广告素材违规（夸大、低俗、未成年不适宜） 游戏与广告落地页不一致（俗称"虚假广告"） 开屏广告"误触""跳转诱导"触发专项治理
沙盒 / 开放世界 / UGC	用户自建、二次创作、 AIGC 风险	低成本生成海量违规内容（血腥、擦边、侵权） 难以管理的公会聊天/私聊 "灰产脚本"利用开放生态牟利 用户付费与内容分成形成复杂合规链条
棋牌 / 模拟博彩类	数值驱动、强社交/竞技属性	赌博化争议、未成年人付费 外部引流黑赌

游戏合规安全特点

在 2025 年的监管体系与行业环境下，游戏产品呈现出区别于其他互联网应用的合规特点，主要体现在内容多样性、风险放大效应、跨平台技术特点以及产业链复杂性等多个维度。其安全特点可概括为以下六方面：

内容类型高度多元，合规覆盖面广

游戏系统由大量异质化内容构成，包括剧情文本、玩法数值、开放世界元素，以及用户生成内容（UGC）、实时语音、公屏聊天、视频直播等多模态信息。这使游戏的内容合规范围远超传统应用，涉及：意识形态风险、色情与低俗、暴力与恐怖内容、赌博化倾向、宗教与民族敏感内容。该多维内容结构对合规体系提出了高频、实时、精准的识别要求。

交互性与沉浸感增强，使内容风险具备放大效应

游戏环境具有强交互、高沉浸、社交密度大等特征，用户在短时间内可与大量玩家沟通、协作或竞争。不良内容一旦出现：触达范围广、传播速度快、情绪传染性强、影响认知与行为的深度更高。这决定了游戏内容风险的治理需具备"更快响应、更高准确率、更强可审计性"。

商业模式复杂，易引发监管关注与社会舆论敏感度

游戏行业普遍采用多因子商业模型，如抽卡概率公示、道具交易、数字资产流转、付费强化等。相关机制容易与监管高敏领域产生交集：未成年人充值争议、赌博化争议（随机机制）、第三方代练、代充、外挂牟利、账户交易与灰产套利。因此，游戏产品在运营周期中需承担更高的消费者保护责任。

跨平台、跨生态运行方式导致技术合规复杂度高

游戏通常需同时支持多个技术生态：Android（多渠道分发体系）、iOS、PC 客户端、主机平台、小程序 / 快应用、云游戏架构。不同平台在权限体系、反作弊机制、数据收集方式等方面差异显著，使隐私合规、权限合规和安全加固工作复杂化。

UGC、沙盒与开放世界类产品提升内容安全挑战等级

随着 UGC、创意工坊、地图编辑器、角色自定义等机制普及，用户从内容消费者转向"内容生产者"。这类产品需要面对：二创角色色情化、自制地图中的违法内容、某些群体的仿真环境传播不良行为、引导未成年人的违规内容、AI 生成内容引发的新型风险。监管对 UGC 场景的要求持续提高，企业需构建从"创作前"到"分享后"的全链路审核机制。

SDK、合作方与第三方服务链条长，连带责任显著增强

游戏通常会接入多类第三方服务，如支付、登录、广告、风控、云存储等 SDK。监管强调"企业需对合作方的个人信息行为承担管理责任"，因此：任意一个 SDK 的权限滥用、第三方服务的数据外泄、隐私政策不一致等都可能引发通报或处罚。在此背景下，游戏行业呈现出"高链路复杂度、高联动风险、高审计要求"的合规特点。

游戏合规治理难点

在政策持续强化、技术门槛提升、产业灰产活跃的背景下，游戏行业的合规治理呈现出多维度、长期化、系统性难题，主要包括以下七类结构性挑战。

多模态内容审核难以平衡精准度、及时性与体验

监管要求严格的"先审后发、全链路可追溯、漏审从严问责"，而玩家群体则强调：审核不应影响社交体验、不应出现明显误判（误伤）、不应出现消息延迟。现阶段 AI 模型仍存在误判，且人工审核成本较高，导致企业在速度、成本、准确率之间长期面临系统性矛盾。

未成年人保护要求持续提升，但绕过手段不断演变

尽管实名制、时长限制、家长监护系统不断完善，但绕过手段持续出现，包括成人协助认证、租号平台、虚拟设备伪装等。这导致：企业需构建"静态身份认证 + 动态行为识别"体系、数据、算法能力要求显著提高、审核、风控团队需长期投入。治理成本呈现逐年上升趋势。

数据合规链条长、跨境环节复杂，工程投入显著提升

游戏在实际运营中涉及大量跨区域服务，例如 CDN、日志分析、云存储、广告变现平台、生成式 AI 工具等。这增加了跨境数据传输、数据共享评估、安全评估（DPIA）、敏感信息加密治理的难度。对中小开发者而言，数据合规已从法律问题升级为工程能力问题。

外挂与灰产产业化，使风控与技术安全持续对抗

外挂、脚本、代练、黑号交易等灰产链条呈现"商业化、自动化、组织化"特征：自动瞄准与 AI 辅助外挂、设备指纹伪装、模拟器批量注册、代练工作室规模化运作。这要求游戏企业投入长期的：客户端安全加固、行为模型识别、设备指纹反虚拟化、日志与数据链路监控。从而形成长期、高成本的"攻防循环"。

多部门重叠监管导致企业需应对多标准、多要求

游戏合规涉及七类监管主体（版署、网信办、工信部、公安部、文旅局、市监局、金融监管），要求包括：内容安全、隐私保护、权限合规、防沉迷、消费者权益、广告规范、网络安全。标准不完全统一、更新频率高，企业需要大量内部协调成本来保持连续合规。

国际隐私法规差异大，出海产品面临多重政策压力

不同国家对个人信息、未成年人、广告追踪、算法透明度要求均存在显著差异：欧盟 GDPR —— 数据最小化、跨境限制、用户权利；美国 COPPA —— 儿童数据保护要求极高；韩国、日本等高度监管国家的本地化要求。出海游戏需要建立兼容多国法规的隐私策略与系统架构，对企业治理能力提出极高要求。

AI、UGC、虚拟人内容增长使监管维度扩张

AI 引导的内容生成体系正在改变游戏内容生产方式，却同时带来新的合规维度：AI 自动生成的剧情与地图、语音变声与虚拟人直播、AI NPC 的对话安全、AI 图像生成的合规性、用户上传的 AI 二创内容。这些因素导致游戏的内容审核体系必须向"多模态 + 多主体 + 全链路"的方向升级。

易盾建议

在 2025 年整体监管持续趋严的背景下，游戏企业亟需构建"可落地、可审计、可持续"的合规运营体系，以应对内容安全、隐私安全、数据安全及未成年人保护的多重要求。基于上述监管趋势和行业痛点，网易易盾从技术、产品与运营三个维度，提出以下可执行的合规建设指引，供游戏从业者参考。

构建实时 + 离线的多模态内容审核体系

为应对文本、图片、语音、视频、直播、多模态 UGC 等场景中快速演化的违规风险，企业需建立「自动化审核 + 人工复核」的协同审查体系。建议架构如下：

自动化审核

- 覆盖关键字、文本分类、OCR、图像识别、语音转写、视频理解、大模型过滤等检测能力。
- 自动计算违规风险分数，确保秒速识别高危内容。

风险分级策略

- 按照内容严重程度设置多级风险区间。
- 高危内容直接拦截，中低风险交由人工复审，提高准确度并保留用户体验。

人工复核

- 对高风险或模型不确定内容进行人工校验，纠正误杀和漏审。
- 审核过程需留存日志、样本与操作记录，以满足监管抽查要求。

通过"机器高效 + 人工兜底"的审查体系，可确保在大体量 UGC 流量中保持高准确度、一致性及可追溯性。

实名制与动态核验体系建设（防代练、防租号、防未成年人绕过）

随着监管对实名制、未成年人保护、账号安全的要求持续升级，企业需完善「静态身份核验 + 实时活体核验 + 行为关联分析」的多因子验证框架：

- 静态证件校验：通过权威数据源完成身份证件真实性校验。
- 活体检测： 防止照片/视频攻击，实现"人证一致"确认。
- 行为关联核验：利用设备指纹、IP 地址、账号操作轨迹、充值行为模型等判断"是否本人使用"。
- 风控降级动作：对可疑账号进行限权、冻结、人工复审等风控措施。
- 日志留存与审计：对核验结果、判定原因留档，满足数据合规要求。

该体系可有效阻断代练行为、租号产业链以及未成年人试图规避监管的行为。

构建未成年人保护的产品体系与家长监护机制

未成年人保护已成为政策最严格、处罚最明确的领域之一。企业应在产品设计、交互路径与家长控制机制上进行全链路建设，包括：

- 突出"未成年人模式"入口：保障发现性、易操作性与可监督性。
- 家长绑定机制：支持监护人对游戏时长、充值额度、社交权限进行控制。
- 消费前置审批：为未成年人提供"购买二次确认"能力。
- 行为提醒与强制下线：时间提醒、冷静期机制、宵禁限制等。
- 制度公示与可查证：在用户协议、隐私政策中明确展示监护能力及操作路径，并提供操作记录以供监管抽查。

通过系统化、可验证的保护体系，可显著降低企业在未成年人管理维度的违规风险。

数据最小化、分级存储与可审计的合规数据治理体系

在《数据安全法》《个保法》《关基条例》等法规影响下，游戏企业需强化对个人信息和敏感数据的管理能力，构建覆盖采集、使用、存储、传输的全链路安全体系：

- 数据最小化原则：仅采集实现业务必要的个人信息，不得超范围收集。
- 敏感数据分级保护：将身份证号、人脸信息、生物特征、手机号等作为高敏数据进行加密、脱敏与访问权限控制。
- 跨境传输合规流程：涉及跨境传输的数据需执行风险评估（DPIA）、个人信息审计等流程。
- 审计与数据留存机制：记录数据访问行为、接口使用记录、异常操作日志，并按监管要求进行定期审计与留档。

该体系可确保企业在数据采集与处理方面均具备可控性、透明性与合规性。

反作弊、代练与黑灰产治理机制

代练、租号、外挂、恶意脚本、虚假充值等黑灰产活动已经成为游戏生态的重要安全风险。企业可通过以下技术手段进行识别与治理：

- 设备指纹识别：标记同一设备上的多账号异常切换、频繁登录等风险。
- 行为建模与风险画像：利用机器学习技术识别"非正常游戏行为轨迹"，包括代练特征、脚本行为、异常战斗数据等。
- 交易链路审计：追查可疑充值、代充、多级倒号链路。
- 账号追踪与风控策略：限制高风险账号交易、提升风控分级、触发人工复核。
- 与监管部门联动：对重大黑灰产线索主动报送，提升治理力度。

系统性的黑灰产治理可有效保护游戏公平性、经济系统稳定性与用户体验。

游戏AI 风险

随着AIGC技术在游戏研发与运营中的广泛应用，安全边界正在重塑。AI技术不仅是创新的引擎，也成为了黑灰产进行"降维打击"的工具。面对这一变化，游戏运营方需警惕以下新型风险并建立相应的防御体系。

当前游戏行业面临的AI安全挑战，主要源于黑灰产对AI技术的工具化利用以及对游戏AI系统的针对性攻击。

常见游戏AI风险类型

基于LLM智能体的自动化工作室体系

随着大语言模型（LLM）能力的增强，游戏工作室的自动化脚本已从"固定路径循环阶段"进化到"智能体（Agent）自主决策阶段"。这些AI智能体配备了感知、记忆、推理和行动模块，能够自主处理复杂的网络游戏环境。

在RPG类游戏中，AI智能体不再是死板地点击固定坐标，而是能够根据任务提示、实时地图反馈及社交对话内容，自主完成跑环任务、资源采集及低级副本的攻略。在SLG类游戏中，跨端脚本已成为主流，作弊者借助PC端的模拟器多开技术，利用AI统一调度数千个账号进行协同作战，其模拟点击风险占比已达31%。这种具备初步"思维能力"的脚本，使得传统的验证码拦截和简单的行为模式匹配在风控治理中捉襟见肘。

生成式AI驱动的社交工程与深度伪造欺诈

生成式AI极大地降低了社交欺诈的技术门槛。黑灰产利用LLM生成极具诱导性的钓鱼文案，或利用深度伪造（Deepfake）技术克隆游戏内名人、工会会长甚至官方客服的语音和形象。

在游戏社交环境中，2025年出现了大量利用AI进行"全渠道欺诈"的案例。攻击者不仅在游戏内频道发布虚假信息，更延伸至Slack、Teams、WhatsApp及Discord等第三方协作平台。通过恶意训练的LLM（如WormGPT、FraudGPT），攻击者可以大规模生成无语法错误、带有特定品牌口吻的钓鱼邮件和站内信，甚至能利用实时语音克隆技术在语音频道中进行诈骗。一项调查显示，这种"克隆服务"在暗网上的起步价格已降至300-500美元。

欺诈类型	传统方式成功率/特征	AI增强方式成功率/特征	风险增益指标
钓鱼信息点击率	12% (含语法错误)	54% (完美拟人化)	4.5倍
身份冒充难度	需长时间社交潜伏	实时语音/视频克隆	极高
文案生成速度	手动编写，难以规模化	毫秒级生成多语言内容	万倍级
欺诈事件增长率	2024基准	2025年增长约2.7%	持续反弹

数据资产泄露与内容安全风险

随着游戏项目体积的急剧增长，代码与资源管理的复杂性为AI自动化的漏洞挖掘提供了契机。黑灰产利用AI扫描工具寻找游戏API的逻辑漏洞，实施非法刷取游戏金币或道具的行为。同时，针对未公开内容的泄密风险也日益严峻。相关泄密事件中，由于内测玩家通过技术手段偷拍偷录并提前公开未发布的角色和技能数据，给经营者带来了难以弥补的商业秘密损失。

此外，AI在游戏内容安全领域也带来了双刃剑效应。一方面，64%的开发者倾向于使用AI填充NPC内容；另一方面，若防御不当，黑灰产可能利用"越狱"后的LLM在游戏社区传播大量违规信息、垃圾广告或政治敏感内容，给平台的合规运营带来极大挑战。

不同类型危害

竞技公平性崩溃与核心玩家流失

对于高度依赖平衡性的竞技类游戏而言，AI外挂是毁灭性的。当普通玩家意识到通过努力练习积累的技巧在AI自动瞄准和低延迟反应面前毫无意义时，其对游戏的忠诚度会迅速瓦解。高端定制挂通过VPN通道营造弱网环境，结合AI预测算法实现"瞬移"和"不掉血"效果，这种极端的不公平直接导致了竞技排位系统的崩塌。

游戏内经济系统的恶性通货膨胀

AI智能体脚本的普及使得游戏金币和稀有物资的产出效率呈指数级增长。黑产工作室通过24小时不间断的AI自动化操作，在极短时间内积累巨额财富。当这些非法产出的资源进入黑市流通时，会导致官方内购货币贬值，正常玩家的劳动产出价值缩水。在RPG游戏中，这种经济系统的失衡会直接触发消费萎缩。

业务反欺诈成本与营销资源的流失

AI风险已深度渗透进游戏的买量与营销环节。在2025年的业务欺诈案例中，黑产利用AI生成大量虚假的商品评价和晒单内容，套取电商平台的"评价返利"和"晒单奖励"。在获取补贴后，黑产通过"仅退款"或"先用后付退款"等流程进一步套利，而AI生成的商品瑕疵图片在细节呈现上已足以通过平台的初步审核。这种自动化作恶对运营方的营销预算造成了严重侵蚀。如果风控系统无法有效识别这些"AI羊毛党"，运营商投入的推广费用将大量流向黑产，而非转化为真实的玩家留存。

品牌信誉受损与法律合规风险

深度伪造和社交欺诈直接威胁到玩家的财产安全，一旦发生大规模受骗事件，游戏运营商往往首当其冲面临信誉危机。同时，随着法律法规对AI技术的"画规"，运营商面临着更严苛的监管要求。2024年5月，全国首例"AI外挂案"的宣判标志着利用AI侵入计算机信息系统已成为严重的刑事犯罪。如果运营方在风控层面存在明显疏漏，不仅会面临玩家的集体诉讼，还可能因未能尽到安全防护义务而受到行政处罚。

AI治理难点

识别界限的模糊化：拟人化特征的极限挑战

AI作弊工具的最高境界是"不可区分性"。通过学习海量人类选手的操作轨迹，2025年的高端AI外挂已能完美复刻人类的反应时间分布、准星移动的加速度曲线乃至非理性的失误表现。传统的统计学检测模型在面对具备"人类特征"的AI模型时，误判率显著上升。在竞技游戏中，一次误封可能导致极大的舆论危机，这使得风控专家在设定封禁阈值时面临巨大的压力。

成本与效率的极度不对称

在黑灰产链条中，攻击者可以利用开源模型和订阅制的恶意工具，快速迭代攻击手段。而防御方需要建立海量的数据采集体系、训练极其复杂的深度学习模型，并支付昂贵的人工核查成本。

维度	攻击方 (黑产)	防御方 (运营安全团队)
技术获取成本	低 (开源模型、订阅制工具)	高 (自主研发、算力投入)
迭代周期	极短 (天级甚至小时级)	较长 (需经过灰度测试与验证)
容错率	高 (封号后可快速换号重来)	极低 (需保证极低的误封率)
算力利用	专注于单一攻击逻辑	需覆盖全量行为监测与分析

环境碎片化与跨端对抗的复杂性

90%的开发者已将移动端作为首选发布平台，80%紧随其后发布PC版。这种跨平台趋势使得安全边界异常破碎。攻击者可以在PC上利用模拟器运行移动端游戏，通过PC端的AI模型指挥移动端的操作。在这种环境下，环境风险检测变得异常复杂。2025年环境风险占总体检测量超60%，显示出黑产在利用环境漏洞方面的技术成熟度。

隐私合规与深度监测的权衡

为了对抗AI外挂，反作弊系统往往需要更深层的系统权限，甚至需要采集屏幕截图、扫描进程列表或监控HID输入流。然而，随着全球对用户隐私保护力度的加强，过度的监测可能触碰GDPR等法律红线。如何在保护玩家隐私的前提下，获取足以支撑AI风控模型运行的行为特征数据，是当前风控体系建设中的一大伦理难点。

网易易盾建议

智能化反制：构建基于AI的行为分析架构

面对AI威胁，防御策略必须实现从"规则特征匹配"向"深度行为语义识别"的进化。运营方应构建基于Transformer或GNN（图卷积网络）的行为分析模型，通过海量的正常玩家操作流数据建立基准线。

- 时空序列特征分析：利用深度学习模型捕捉玩家在游戏内移动、瞄准、交互的时空关联性。AI外挂虽能模拟微观的随机抖动，但在宏观的游戏逻辑决策，如寻找敌人的路径选择、对战场信息的综合感知上，往往表现出与人类玩家截然不同的"机械优越性"或"信息超前感"。
- 多模态异常检测：结合客户端环境数据、网络协议特征、输入流规律及社交文本内容，构建多维度的风险评分模型。

零信任架构与环境加固

由于传统的边界防护已难以阻断AI驱动的渗透，建立"零信任（Zero Trust）"的游戏内风控架构至关重要。

- 持续验证机制：不再仅仅依赖登录时的身份验证。在游戏全生命周期中，对关键业务接口，如交易、结算、高价值道具产出，实施持续的行为验证。
- 硬件指纹与底层对抗：加强对DMA板卡、HID模拟硬件及新型模拟器的识别技术。针对内核级的篡改，应部署更强健的驱动保护层。
- VPN与代理网络治理：鉴于15%的高端定制挂利用VPN营造弱网环境，系统应具备识别复杂网络环境并实施针对性风控策略的能力。

构建【账号信用分】体系，实施'精细化'分级治理

结合上述识别结果，建立账号信用分体系。对于高风险但证据稍显不足的账号，不直接封禁，而是限制其社交频次或收益效率，在保障正常玩家体验的同时，最大限度压制黑产的生存空间。

游戏营销风险

随着游戏行业市场竞争加剧，买量推广、渠道合作、广告投放等营销手段已成为游戏获取用户、提升营收的核心路径。但营销链路的多元化与开放性也为黑灰产渗透、合规风险爆发提供了可乘之机，营销安全已成为影响游戏产品生命周期与市场生态的关键环节。

游戏营销风险类型

游戏营销风险可划分为三大核心类型，涵盖渠道合作、广告投放、舆情传播：

渠道作弊类风险

此类风险源于营销渠道与黑灰产的协同作弊，核心目标是骗取推广费用或不正当获取分成收益，主要包括三种具体形态：一是CPA/CPS模式下的虚假刷量，渠道通过设备群控、真人众包、设备多开等方式伪造虚假用户下载、注册行为，形成无真实活跃价值的"僵尸账号"；二是渠道违规拉人，通过单独开新服截留官服用户、以折扣充值/返利活动诱导官服玩家流向渠道服，甚至在混服场景中通过线下交易洗取官服流水；三是违规代充，渠道通过低价首充、持续性折扣充值等违规服务吸引玩家，破坏游戏充值体系公平性。

广告合规类风险

此类风险源于广告内容、投放方式或数据使用违反法律法规与行业规范，具体包括：一是虚假宣传，广告内容与游戏实际体验不一致，夸大游戏收益、功能效果或隐瞒付费风险；二是数据隐私违规，未明确告知用户数据用途即采集游戏行为数据用于个性化广告推送，或过度收集非必要用户信息；三是未成年人权益侵害，在未成年人集中时段/场景投放诱导性广告，未通过实名认证限制未成年人消费行为。

营销舆情类风险

此类风险源于营销活动设计不当或内容争议引发的负面舆论扩散，包括：一是营销内容引发价值观冲突，如包含宗教禁忌、性别歧视等敏感内容；二是激励机制诱导过度消费，如设置"限时折扣"等强制性提示，未提供明确退出机制；三是活动规则不透明，如奖励发放延迟、条件设置暗藏陷阱，引发玩家集体投诉与负面传播。

不同类型的危害

游戏营销风险可划分为三大核心类型，涵盖渠道合作、广告投放、舆情传播：

渠道作弊类风险危害

经济层面上，游戏厂商推广费用被大量浪费，花费一样的推广费用吸引到的却是不真实、无价值的玩家，虚假流量导致的异常推广费用消耗大部份推广预算；运营层面，虚假用户导致次日留存率、付费率等核心指标失真，干扰A/B测试结果与产品迭代决策，优质渠道被劣质作弊渠道挤压，形成"劣币驱逐良币"的市场扭曲；游戏生态层面，违规代充与渠道拉人破坏游戏内经济平衡，引发官服玩家不满，加剧用户流失，破坏厂商与渠道的信任关系。

广告合规类风险的危害

监管层面，违规广告可能触发《广告法》《个人信息保护法》等法规处罚，面临罚款、广告下架甚至游戏停服整改的后果，跨境营销时还可能因违反欧盟GDPR、美国COPPA等海外法规遭遇市场准入限制；品牌层面，虚假宣传与隐私泄露会严重损害用户信任，导致品牌声誉崩塌、用户主动流失；用户层面，诱导消费与不规范广告推送侵犯用户自主选择权，未成年人广告违规可能引发社会舆论谴责，扩大风险影响范围。

营销舆情类风险的危害

短期危害表现为负面舆论快速扩散，社交平台形成集中吐槽潮，直接影响新用户转化与老用户留存；长期危害则是游戏品牌形象固化负面标签，降低用户付费意愿与口碑传播意愿，对游戏产品生命周期产生不可逆影响。

游戏营销安全攻防战

游戏营销安全攻防本质是黑灰产作弊手段与安全防控技术的动态对抗，攻击方具备以下特点：

技术层面

作弊手段从单一设备作弊升级为团伙化、智能化操作，通过设备指纹篡改、虚拟机伪装、代理IP池切换等方式规避单一检测规则，甚至利用AI生成虚假用户行为数据，提升作弊隐蔽性；

模式层面

从直接刷量转向"精细化作弊"，如培养低活跃度"养号"群体模拟真实用户行为，或通过线下社群组织真人完成基础、简单的游戏任务，规避平台风控阈值；

渠道层面

利用不同渠道间的规则差异，通过多渠道拆分作弊量、跨包体流转用户等方式分散风险，增加检测难度。

而这些特点造成了游戏营销安全防御存在以下诸多难点：

多渠道管控碎片化

游戏营销涉及应用商店、短视频平台、主播合作等多种渠道，不同渠道的操作流程、数据接口、风控标准存在差异，导致厂商难以实现集中化数据统计与风险监测，部分中小渠道合规意识薄弱，成为作弊风险高发区。

作弊手段隐蔽性与迭代速度快

黑灰产通过技术迭代快速规避现有防控规则，从"硬作弊"转向"软作弊"，虚假用户行为与真实用户差异不断缩小，单一检测指标难以精准识别，防控体系需要持续迭代以应对新作弊手段。

营销与安全协同不足

营销团队核心目标是提升拉新量与转化率，可能存在"重效果、轻安全"的倾向，在推广节点为追求短期效果放松风控标准；跨部门数据共享不及时，营销数据与安全数据割裂，导致风险识别滞后。

跨境合规复杂性高

游戏出海营销需同时遵守不同国家/地区的广告法规、数据隐私法规，如欧盟GDPR的数据跨境传输限制、韩国《广告自律准则》的标识要求等，法规差异大、更新频繁，增加了合规治理难度。

舆情风险不可预见性强

营销内容的受众认知存在个体差异，部分看似合规的内容可能因社会热点关联引发意外负面舆情，舆情传播速度快、影响范围广，应急处置窗口时间短。

游戏私服风险

私服是未经版权方授权，非法获取游戏服务器端程序并架设运营的网络盗版服务器，属于侵害著作权的违法行为。其通过复制正版游戏数据建立独立服务器，多以收费获利为目的，玩家权益缺乏法律保障且面临安全风险。部分私服运营商允许自定义游戏内容，破坏市场竞争秩序，严重损害正版游戏的商业利益和品牌声誉。

私服按技术实现方式可分为两大类：端侧破解版私服通过修改游戏客户端，使用Patch和包体修改手段绕过验证机制，玩家可连接至非法服务器；完全重写私服则是通过代码泄露、逆向工程等方式获取服务端核心逻辑，重新搭建独立的游戏服务器环境。前者技术门槛较低，后者需要较高技术能力但隐蔽性更强，对正版游戏的冲击也更为严重。

游戏私服风险类型

- **商业利益受损**：分流正版玩家的付费能力，直接导致官方营收下降。
- **品牌声誉破坏**：私服通常质量低下且缺乏监管，玩家在遭遇不良体验后可能迁怒于正版IP，导致品牌口碑崩塌。
- **市场秩序扰乱**：私服通过恶性低价、变态数值等手段破坏游戏的公平性认知，影响正版游戏的生命周期。

不同类型的危害

- **端侧破解私服危害**：

设备安全威胁：客户端容易被植入恶意代码、挖矿程序或病毒，直接威胁玩家设备安全。

体验极不稳定：由于是暴力破解，游戏过程中可能存在大量 Bug、闪退和掉线问题，数据由于缺乏校验容易回档。

- **完全重写私服危害**：

冲击正版生态：此类私服还原度高，且往往提供"变态福利"，对正版游戏造成更大的冲击，加速玩家流失。

数据隐私泄露：私服服务器缺乏安全防护，可能包含恶意代码，严重威胁用户数据安全。

财产诈骗风险：运营者可能通过后台恶意手段获取用户的个人身份信息、银行卡号等隐私，甚至直接实施充值诈骗或卷款跑路。

游戏私服安全攻防战

端侧技术对抗手段

游戏厂商在技术层面采取多重防护措施：

- **客户端加固**：使用代码混淆、虚拟机保护（VMP）、完整性校验等技术，提高逆向工程和篡改的难度。
- **通信安全**：采用通信协议保护、动态密钥生成、**以及数据包加密传输技术，防止协议被抓包、分析和伪造，确保客户端与服务器通信的唯一性与安全性。**

防止代码泄漏

建立健全的内部代码保护机制，实施严格的权限分级管理，防止服务端核心代码及美术资源外泄。同时，利用法律武器打击侵权，对泄密源头进行溯源和追责

法律与协同治理

除技术手段外，法律途径是打击私服的重要武器。游戏厂商积极配合公安机关，通过刑事报案追究私服运营者的侵犯著作权罪、非法经营罪等法律责任，近年来已有多起私服案件被判处有期徒刑并处罚金。同时，游戏厂商与应用商店、支付平台、云服务商等建立协同治理机制，通过下架私服应用、冻结违法账户、封禁服务器IP等方式切断私服的传播和盈利渠道。行业协会也在推动建立私服黑名单共享机制，形成全行业联防联控的态势。

游戏私服问题特点

- **传播快**：利用社交群组、短视频平台等渠道快速裂变。
- **危害大**：持续扩大危害，若不打击，会给玩家造成"官方不管"的错觉，加快玩家流失到私服。
- **重合度高**：私服玩家与真实玩家重合率高，极易转化正版核心用户

游戏私服治理难点

- **源码已泄漏**：一旦服务端代码泄露，会衍生出无数变种，对抗成本极高。
- **剥离难度大**：新增的安全检测和对抗逻辑容易被私服开发者识别并剥离。
- **防守成本高**：私服产业链利益巨大，黑产投入大，厂商处于被动防守地位，取证和打击成本高昂

其他游戏风险

出海数据合规

本指南聚焦国内游戏厂商出海过程中的数据合规痛点，整合中国及海外主流市场（欧盟、美国、日本等）的核心监管要求，梳理典型风险场景并提供可落地的应对方案，助力厂商平衡业务发展与合规底线。

游戏出海数据合规需同时满足"中国数据出境监管"与"目标市场数据保护法规"双重要求，二者环环相扣，缺一不可。

监管主体	关键依据/法规	核心合规要求
中国 （数据出境端）	1. 重要数据出境需通过国家网信部门安全评估，申报需在被认定为重要数据后2个月内完成；2. 遵循"最小必要"原则，非必要数据不得出境；3. 与境外接收方签订数据安全保护合同，明确双方责任。	《数据安全法》 《网络数据安全管理条例》 《数据出境安全评估办法》
欧盟 （主流市场）	1. 玩家拥有数据访问、删除、更正权，企业需响应用户请求；2. 数据采集需获得玩家明确同意，禁止默认授权；3. 数据本地化存储优先，确需出境需满足"充分性认定"或合规保障措施。	《通用数据保护条例》（GDPR）
美国 （主流市场）	1. 加州CCPA要求企业公示数据采集范围与用途，玩家可要求删除个人数据；2. 苹果iOS 14.5+需通过App Tracking Transparency功能获得玩家跟踪授权；3. 联邦层面强调数据泄露及时通知。	《加州消费者隐私法案》（CCPA）、 苹果App Store隐私规则
日本 （高潜力市场）	1. 遵循《个人信息保护法》，数据采集需明确告知目的并获得同意；2. 敏感个人信息（如生物识别数据）采集需单独获得授权；3. 与第三方共享数据需提前通知玩家。	《个人信息保护法》、 日本总务省数据监管细则

高风险场景警示

游戏出海数据合规风险贯穿"数据采集-传输-存储-使用"全链路，以下为高频风险场景及实际案例警示：

数据过度采集

数据过度采集引发信任危机部分厂商为反作弊或精准营销，采集玩家设备IMEI、通讯录、位置轨迹等非必要数据，违反"最小必要"原则。例如欧盟曾对某中国手游厂商处以年营收4%的GDPR罚款，原因是未明确告知玩家数据采集范围。

重要数据出境未申报

重要数据出境未做安全评估游戏运营数据（如用户行为日志、付费记录）若被认定为重要数据，未申报安全评估即传输至境外服务器，可能面临数据出境禁令。2025年某厂商因未合规申报，导致海外服务器数据无法同步，影响300万海外玩家体验。

数据存储与删除

全球法规冲突应对失当美国法院曾要求AI平台无限期保存用户数据，而欧盟GDPR明确用户有权要求删除数据，这种冲突导致部分中国厂商陷入"合规两难"。某手游因未及时响应欧盟玩家的删除请求，被下架欧洲应用商店。

数据存储选择

本地化存储落实不到位日本、德国等市场要求核心数据本地存储，部分厂商为节省成本将数据回流至国内服务器，被当地监管部门责令整改，整改期间游戏下载量下降40%，直接影响营收。

全链路合规应对策略

合规环节	具体应对措施	工具/技术支撑
数据采集阶段	1. 制定分地区数据采集清单，欧盟/美国市场仅采集账号、付费信息等核心数据，放弃非必要采集； 2. 采用"弹窗分层授权"，敏感数据单独获取同意，避免"一揽子授权"； 3. 同步提供简体/繁体/英文等多语言隐私政策，明确告知数据用途。	隐私政策生成工具、多语言合规文案模板
数据传输阶段	1.委托第三方机构完成重要数据识别，确需出境的按《数据出境安全评估申报指南》流程申报； 2. 采用加密传输协议（如TLS 1.3），防止数据传输中泄露； 3. 与境外合作方签订合规协议，明确数据保护责任。	数据分类分级系统、加密传输工具
数据存储阶段	1. 按"就近存储"原则，欧盟数据存法兰克福服务器、日本数据存东京服务器，避免跨境回流； 2. 对玩家数据进行脱敏处理，去除姓名、手机号等原始标识； 3. 定期清理过期数据，响应GDPR"被遗忘权"要求。	分布式云存储服务（AWS/阿里云海外节点）、数据脱敏系统
运营响应阶段	1. 搭建多语言数据合规申诉通道，24小时内响应玩家数据查询、删除请求； 2. 定期开展合规审计，重点排查欧盟、美国市场的隐私政策落实情况； 3. 建立数据泄露应急机制，按当地法规要求及时公示。	智能客服系统、合规审计工具

此外，日本作为中国游戏出海高潜力市场（2025年中国手游占据日本收入榜前十中的六席），需额外关注其"孤独经济"下的用户数据保护偏好——玩家对个人信息泄露容忍度极低，建议在本地化运营中强化隐私保护宣传，提升用户信任。

网易易盾建议

建立跨部门合规团队：由法务、技术、运营人员组成专项团队，实时跟踪目标市场法规更新（如欧盟GDPR修订、日本个人信息保护法增补条款）。

借助SaaS化合规工具：接入第三方数据合规SaaS服务，实现数据分类分级、合规检测、用户请求自动响应等功能，降低中小厂商合规成本。

绑定本地合规资源：在欧盟、美国、日本等核心市场合作本地律所，应对突发合规调查，确保整改措施符合当地监管要求。

IP与内容侵权

游戏IP内容合规是游戏出海的"第一道门槛"，涵盖IP创作授权、内容表达、本地化适配等全环节，直接关系到游戏能否顺利准入目标市场及IP的长期价值。尤其在监管趋严背景下，内容合规已从"风险规避"升级为IP全球化运营的核心竞争力。

游戏IP内容合规需兼顾"中国文化出海导向"与"目标市场监管规则"，核心围绕版权、价值观、特殊群体保护三大主线展开。

合规维度	国内监管要求 （出海前置条件）	海外重点市场要求 （准入核心标准）
版权合规	1. 原创IP需完成著作权登记，明确权利归属；2. 授权IP需核查授权链条完整性，避免"二次授权""超范围授权"风险；3. 不得抄袭、改编无授权的第三方IP（含文字、美术、音乐等）。	1. 美国《数字千年版权法》要求及时响应版权投诉，建立"通知-删除"机制；2. 欧盟对IP授权文件的本地化公证要求严格，需提供多语言版本；3. 韩国、日本要求游戏内美术、音乐等素材单独完成版权备案。
内容价值观	1. 符合社会主义核心价值观，避免宣扬暴力、色情、赌博等不良内容；2. 历史题材IP需尊重历史事实，不得歪曲重大历史事件及人物；3. 宗教元素表达需保持中立，不得歧视或极端化呈现。	1. 欧盟禁止含种族歧视、宗教极端内容，中东市场需符合伊斯兰文化禁忌（如避免饮酒场景、女性形象适度着装）；2. 美国通过"黑暗模式指南"规制游戏内诱导消费内容，如战利品箱需明确概率披露；3. 韩国GRAC认证要求游戏内容不得违背《青少年保护法》，暴力场景需做模糊处理。
特殊群体保护	1. 未成年人内容需设置分级提示，避免过度商业化诱导；2. 不得包含歧视残障人士、特定群体的内容表达。	1. 美国公平贸易委员会重点监管未成年人保护，要求游戏设置年龄验证、家长授权环节，某中国手游因缺失该环节被罚2000万美元；2. 欧盟GDPR联动内容监管，未成年人个人信息保护与内容分级需同步落实；3. 韩国2025年实施的"国内代理人制度"，将未成年人内容投诉处理纳入强制响应范畴。

高频风险场景及典型案例警示

IP内容合规风险贯穿游戏生命周期，以下为出海过程中高发的风险场景及实际案例，为厂商提供直观警示。

风险1：授权IP链条断裂引发侵权纠纷某中国厂商代理日本某动漫IP开发手游，未核查到授权文件已过期，游戏在日本上线3个月后被版权方起诉，不仅被迫下架，还承担了1.2亿日元的赔偿，IP合作信誉受损。

风险2：本地化不足触碰文化禁忌某武侠IP手游出海中东时，未删除游戏内饮酒、猪肉相关场景，违反伊斯兰文化禁忌，被当地监管部门直接下架；另一款游戏在韩国上线时，因历史人物服饰设计与韩国传统服饰存在差异，引发玩家抗议，被迫紧急修改并公开致歉。

风险3：未成年人保护缺失触发高额处罚2025年1月，美国公平贸易委员会以"未设置未成年人年龄填报环节""明知是未成年人却无家长授权界面"为由，对某中国出海手游提起诉讼，企业最终以2000万美元和解，类似案例在EPIC《堡垒之夜》等国际大厂中也多次发生。

风险4：内容表达模糊引发监管争议某科幻IP手游因"战斗场景血液颜色未做处理""任务对话含隐晦暴力描述"，在欧盟申请发行时被判定为"不适宜青少年"，需额外投入百万级成本修改内容后才通过审核，错失上线窗口期。

全链条合规应对策略

IP运营环节	具体应对措施	落地工具/资源支撑
IP创作/授权阶段	1. 原创IP：完成著作权、商标权全类别登记，形成"权利包"；2. 授权IP：委托本地律所核查授权链条，明确授权期限、地域、使用范围，留存公证文件；3. 跨界IP合作（如影视、动漫联动）需签订"合规兜底条款"，明确双方责任。	知识产权管理平台、跨境律所IP核查服务
内容开发阶段	1. 建立"内容合规清单"：按目标市场分类标注禁忌内容（如中东禁饮酒、欧美禁种族歧视）；2. 历史/宗教题材需邀请文史专家审核，避免事实偏差；3. 未成年人相关内容：预设年龄验证模块，氪金功能添加家长授权弹窗。	内容合规审核系统、文史专家库、本地化顾问服务
本地化适配阶段	1. 语言适配：避免直译导致的语义偏差，如韩国市场需区分正式语与非正式语使用场景；2. 文化适配：中东市场替换猪肉、饮酒素材为符合伊斯兰文化的替代内容，欧美市场弱化"集体主义"相关表述；3. 合规文件适配：按GRAC（韩国）、PEGI（欧盟）等评级机构要求提交多语言审核材料。	母语级本地化团队、目标市场评级机构前置咨询服务
运营维护阶段	1. 建立内容投诉快速响应机制，24小时内处理版权、文化禁忌相关投诉；2. 跟踪目标市场法规更新，如美国"概率玩法披露""未成年人保护"等监管重点变化；3. 定期开展内容合规审计，尤其在重大节日、政策调整前完成风险排查。	多语言客服系统、监管政策预警工具、合规审计服务

特别提示：韩国作为2025年中国游戏出海的核心市场之一，其GRAC认证和"国内代理人制度"需重点关注。建议在韩国市场提前6个月启动内容审核准备，指定本地代理人并完成GRAC报告提交，避免因合规滞后影响上线节奏。

网易易盾建议

搭建IP合规中台：整合版权管理、内容审核、本地化适配三大模块，实现IP从创作到出海的全流程合规管控，尤其对多市场发行的IP进行"合规标签化"管理（如"中东版""欧美版"内容差异标注）。

联动本地生态资源：在韩国、美国、欧盟等核心市场，与本地律所、评级机构、文化咨询公司建立长期合作，获取前置性合规建议，降低审核风险。

建立合规培训体系：定期对IP创作、运营团队开展跨市场合规培训，重点讲解文化禁忌、监管案例，避免因"经验主义"导致的合规失误，如避免照搬美国本土厂商经验而忽视自身游戏类型的合规差异。

不同游戏安全风险概述

游戏风险主要与游戏品类强相关，MMO等存在经济系统类的游戏，一定会滋生搬砖工作室、脚本群体；FPS等强对抗类的游戏，一定会存在严重的修改器、盗版情况；卡牌等长期养成类的游戏，一定会存在代肝、初始号贩卖的问题。当前项目组外挂治理工作均围绕脚本、修改器、盗版、工作室展开。

说明：本表格基于网易易盾2025年游戏安全检测与对抗数据编制，风险占比以"该类型游戏中某风险的发生频次/该类型游戏总安全风险频次"计算。

风险类型	游戏类型及风险占比					
	RPG游戏（角色扮演）	FPS游戏（射击类）	SLG游戏（策略类）	棋牌游戏	传奇游戏	小游戏（休闲类）
外挂	25%（自动打怪、资源透视为主）	72%（自瞄、透视挂占比超80%）	22%（加速挂、视野挂居多）	30%（记牌器、透视挂核心）	17%（加速挂、无敌挂为主）	18%（分数修改、无限道具）
打金工作室	32%（多开脚本产装备金币）	3%（少量账号练等级）	28%（资源采集、多账号控盟）	15%（批量刷金币兑现实货币）	24%（挂机打怪捡宝支撑私服）	2%（经济体系简单需求低）
违规内容	8%（辱骂、低俗信息）	12%（辱骂信息占比68%）	5%（联盟冲突辱骂为主）	20%（赌博话术占比超60%）	5%（交易纠纷辱骂）	12%（低俗表情包、辱骂）
违规营销	15%（装备代刷、账号交易）	4%（外挂售卖广告）	20%（代充折扣、账号代练）	25%（现金兑换、赌博引流）	22%（装备回收、一刀999宣传）	7%（付费道具低价诱导）
盗版私服	18%（传奇类RPG衍生私服为主）	/	15%（三国、战争题材居多）	3%（少量换皮盗版）	31%（占全行业私服58%）	1%（多为破解版而非私服）
演员	5%（副本恶意划水）	8%（排位赛故意送分）	4%（联盟战消极作战）	7%（伙牌作弊）	/	/
破解	5%（付费 DLC 破解）	2%（反作弊强破解少）	5%（资源购买系统破解）	4%（付费房间破解）	3%（私服自带破解属性）	22%（付费关卡破解率45%）
违规广告	2%（内置弹窗广告）	1%（官方运营规范）	6%（联盟招人广告）	6%（第三方赌博广告）	2%（私服引流广告）	38%（强制弹窗占比超90%）

数据补充说明：

1. 传奇游戏私服风险中，43%包含外挂功能，52%为换皮侵权，需同步防控双重风险；
2. 小游戏破解版中60%存在隐私数据采集、资费暗扣等高危行为，远超合规版本安全风险；
3. FPS游戏外挂样本量2024年增长93%，需重点强化AI行为检测技术投入。
4. 部分安全事件会同时触发多种风险，统计时需分别计入对应类别，导致重复计算，同类游戏风险占比会出现≥100%的情况。

风险防控优先级指引

高优先级（核心风险占比≥30%）：FPS游戏（外挂）、传奇游戏（盗版私服）、小游戏（违规广告）、RPG游戏（打金工作室），需配置专项防控资源。

中优先级（核心风险占比20%-30%）：SLG游戏（打金工作室、违规营销）、棋牌游戏（外挂、违规营销、违规内容）、小游戏（破解），需建立常态化监测机制。

低优先级（核心风险占比＜20%）：各类游戏的低发风险（如FPS游戏私服、小游戏演员），可通过通用安全策略覆盖，无需专项投入。

RPG游戏风险

角色扮演类游戏（Role-Playing Game，简称RPG）作为一种强交互、强故事性，兼具对战（PVP）、养成副本（PVE）等游戏类型，玩家在游戏中扮演一个或多个角色以养成数值的方式提升游戏体验。

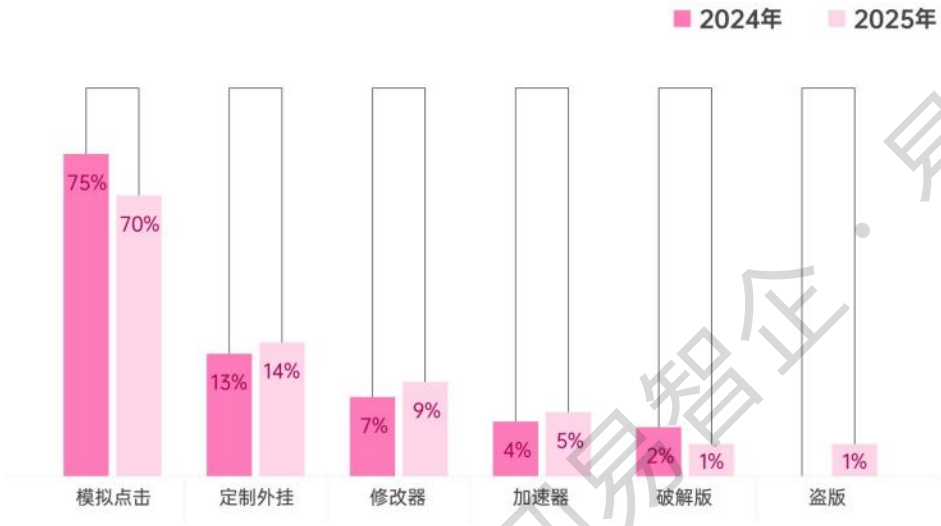
目前，角色扮演类游戏分支常见如：**大型多人在线角色扮演游戏（MMORPG）和动作角色扮演游戏（ARPG），其中前者以互动、养成为主，而后者则更加侧重于动作战斗。**

根据网易易盾2024年检测数据显示，角色扮演类游戏模拟点击、修改器、定制外挂问题、加速器最为严重。

网易易盾检测出占比情况：模拟点击70%、定制外挂14%、修改器9%、加速器5%、破解版1%、盗版1%。

模拟点击作为角色扮演类游戏（RPG）的重灾区，主要表现在作弊玩家/黑灰产工作室利用脚本进行自动任务、自动跑环、自动领取奖励、自动战斗、自动采集资源、快速升级技能等。而后黑灰产工作室则会通过私域、主播、工会、自建站、电商平台等渠道对其获得的道具、游戏币、角色等进行兜售和集中售卖，以此谋取收益。

另外，如前文提到的RPG游戏涵盖了MMORPG、ARPG、传奇游戏等，在风险问题也存在一定差异，比如APRG游戏中云真机、模拟点击、模拟器最为严重。



2024-2025 角色扮演类游戏外挂占比对比

从以上游戏外挂类型来看，作弊玩家多采用多种技术手段去影响角色扮演类游戏的均衡运行，我们以打金工作室为例，打金工作室使用高端定制挂，通过虚拟手机号进行预约，利用云手机、模拟器多开、设备墙、虚拟机等批量创建登录，并在囤好阶段用脚本批量囤号升级，部分工作室直接出售成品任务号，在打金阶段则通过多开工具实现同屏多开，利用脚本工具，群控自动打金。

以某传奇客户为例，工作室通过模拟器复制、镜像和重装APP等手段，躲避业务方自建的IP聚合，以此实现单PC无限多开的效果。

以某DNF类游戏为例，游戏允许单账号创建多角色切号操作，通过手机设备墙实现团伙多开，利用PC甲苯对设备进行群控操作，实现团伙打金。

FPS游戏风险

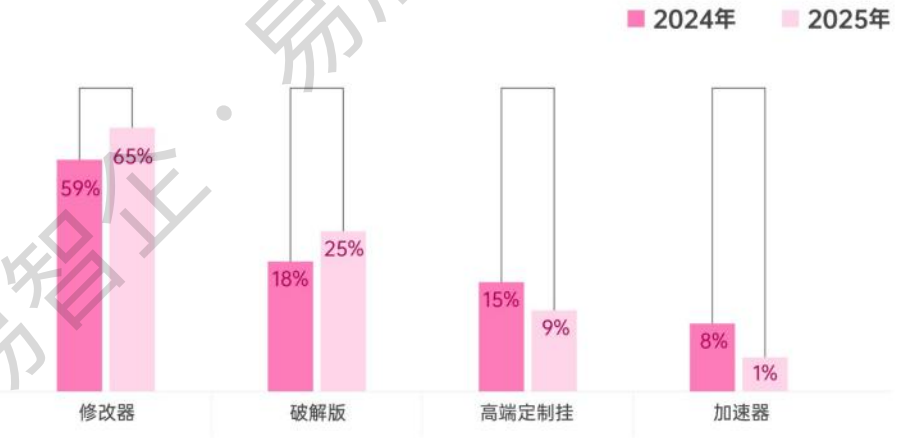
第一人称射击类游戏（First-Person Shooter, FPS）是射击类游戏的一个分支，在FPS游戏中，玩家通过游戏角色的视角直接体验游戏世界，这种视角使得玩家能够更直接地感受到射击的快感和战斗的紧张感。

根据网易易盾2024年检测数据显示，第一人称射击类游戏修改器、破解版、加速器、高端定制挂（外挂价格≥1000元/月）最为严重。

网易易盾检测出占比情况：修改器65%、破解版25%、高端定制挂9%、加速器1%。

其中修改器主要是玩家通过修改游戏内存和关键资源文件，实现自动瞄准、锁头、瞬移、飞天遁地、透视等辅助对战效果，同时也会通过修改器修改生命值、弹药、子弹伤害、压枪的稳定性等数值数据，以此提升获胜概率。

此外，FPS游戏的高端定制挂呈现出上升趋势明显，比如外挂通过VPN通道，营造弱网、丢包、延迟等网络环境，实现游戏内瞬移、不掉血等效果。



2024-2025 第一人称射击类游戏外挂占比对比

SLG游戏风险

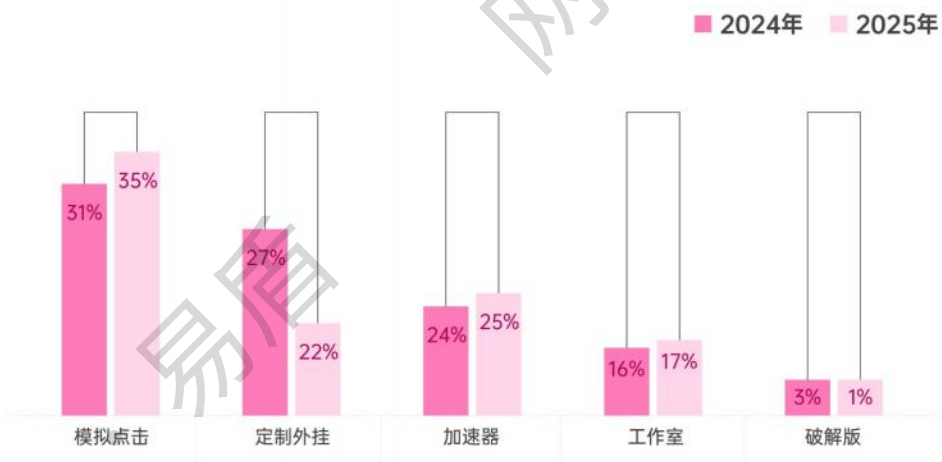
SLG游戏是一种策略游戏，玩家需要在实时进行的游戏中做出快速决策，指挥和管理资源，以及指挥军队进行战斗。这类游戏通常涉及基地建设、资源采集、单位生产和战术部署等多个方面。

策略类游戏玩法相对复杂，结合了资源管理与占领、单位控制、多人对战、基地建设等多种内容。根据网易易盾2024年检测数据显示，即时战略类游戏常见游戏风险问题中模拟点击、加速器、工作室、破解版、定制外挂最为严重。

网易易盾检测出占比情况：模拟点击35%、定制外挂22%、加速器25%、工作室17%、破解版1%。

其中，模拟点击问题主要表现在玩家通过使用自动脚本实现自动建造、自动采集资源、无限人口、地图全开、单位无敌等。而恶意应用则主要包括群控应用（掘金）、autojs框架（用于开发各类辅助）、easyClick框架、投屏工具等。

另外，跨端脚本在SLG游戏中问题较为主流，比如作弊玩家通过在PC上执行按键精灵类脚本，利用模拟器多开，批量控制运行在内的游戏，实现自动化操作。



2024-2025 即时战略类游戏外挂占比对比

棋牌类游戏风险

棋牌类游戏是一种传统的游戏类型，它包括了各种使用牌、棋盘或两者结合的游戏。这类游戏通常需要玩家运用策略和技巧，以及一定的运气成分。棋牌类游戏可以追溯到古代文明，并且至今在全球范围内仍然非常流行。

棋牌游戏种类多样，例如麻将、飞行棋、纸牌、战旗等等，根据网易易盾检测，棋牌类游戏产品工作室问题最为严重。

工作室通过批量创建资源号、多开等方式进行资源和金币转移至固定聚金号，再通过指定房间吸引付费用户参与对局以转移资源和支持对方上榜。此外，黑灰产工作室还会组队方式组局进行杀猪盘，从而赚取玩家游戏道具和金币。

比如某棋牌游戏工作室，通过模拟器复制、镜像和重装APP等手段，躲避业务方自建的IP聚合，实现单PC无限多开。此外，某捕鱼类游戏过手机设备墙实现团伙多开，利用PC脚本对设备进行群控操作，实现批量升级获取资源后进行兜售。

传奇类游戏风险

传奇类游戏通常是指以《传奇》系列游戏为模板或灵感来源的MMORPG游戏。传奇类游戏在玩法上主要包含以打怪直接掉落装备的PVE玩法和玩家与玩家之间打架的野外PVP玩法。

传奇游戏由于在游戏玩法设计上一般都会制造游戏资源的稀缺性以刺激玩家进行资源争夺，所以游戏工作室问题尤为严重，特别是部分工作室利用模拟器进行复制、多开抢夺游戏资源进行售卖。

小游戏风险

小游戏通常指那些体积小、玩法简单、易于上手的游戏，它们可以在各种平台上快速运行和体验，不需要复杂的安装和配置过程。小游戏通常以休闲益智类主题为主，深受在某些特定场景下用户的喜欢。当然这里的小游戏不仅仅是指以小程序形式加载的类型，也包括最后打包成比较小的安装包形式的游戏，比如cocos2djs等类型。

小游戏问题主要集中在盗版的风险，大多数的都是对一些"原始的游戏"进行"二次改包"快速的打包形成新的安装包，达到一些不可告人的目的，同时可能在里面加入一些恶意行为等等。

比如资源盗版可能是一些游戏的比较大的痛点，由于小程序结构的简单性，攻击者可以在不修改任何代码的情况下直接进行解包出来的文件中对资源进行窃取，然后重新打包进行发布等。

03

游戏安全趋势观察



游戏安全已从单一反外挂对抗，升级为覆盖反外挂、黑灰产治理、内容风险防控、账号安全保护及合规隐私保障的全维度综合治理体系。对抗重心正从应用层向内核 / 硬件层下沉，同时深度融合 AI 行为分析技术；如今，安全已成为游戏实现长线稳定运营的核心生命线。

核心趋势	变革背景（痛点/现象）	未来方向（趋势/策略）
防御手段"AI化"	AI催生非侵入式作弊，极致模仿人类行为，隐蔽性极强；传统特征识别、规则拦截等反外挂技术几乎失效，无法精准捕捉作弊痕迹。	"以AI反AI"成为核心思路：通过AI模型深度学习正常玩家操作基线，结合行为验证与"玩家信用分系统"实现分层管理；对低信用玩家采用隔离匹配、功能限制等柔性措施，替代简单封号。
跨端作弊治理升级	移动端与PC端跨端体验普及，黑灰产通过CE修改模拟器数据、模拟点击操控海量账号作弊，外挂隐蔽性倍增，黑产效率提升数十倍，传统检测仅能识别环境无法判定作弊。	构建多维度检测体系：融合行为检测、侧信道检测技术，精准区分正常跨端玩家与作弊行为；针对黑灰产工作室特点，建立设备-账号-行为关联分析模型，实现定向打击。
权限约束下的攻防平衡	移动端隐私合规收紧，《个人信息保护法》等政策严控权限，游戏安全系统操作空间被压缩；而作弊者仍可突破管控，形成"防守方受限、攻击方无界"的不对等局面。	转向非侵入式检测创新：通过用户长期行为画像异常挖掘、设备可信状态交叉验证、应用链路隐性数据轨迹分析，在合规范围内最大化挖掘数据价值，实现高效风控。
安全能力SaaS化普惠	独立游戏与中小厂商缺乏专业安全团队；中大型厂商面对快速变异的作弊技术也力不从心，安全能力成为行业发展不均衡的核心瓶颈。	安全服务标准化封装：安全厂商将反加速、防修改等能力转化为标准API与SDK，厂商接入即可获得顶尖防护；配套提供持续更新、应急响应服务，实现"接入即防护"。
内核级反作弊信任重构	反作弊程序权限升高引发隐私担忧，Windows时代曾因数据采集限制宽松，出现过度收集问题；玩家对内核级程序的信任度持续走低，成为行业信任痛点。	移动端合规重塑信任：依托手机系统严格的采集限制与合规监管，反作弊程序遵循"最小必要"原则；公示数据采集清单，通过等保2.0认证，消除过度采集风险。
软作弊治理成新重点	"暴力挂"减少，但"演员"、代练、炸鱼等软作弊凸显，其破坏匹配公平性的危害更受玩家痛恨；如何区分"菜"与"演"成为检测难点，也是玩家投诉重灾区。	建立软作弊分级治理体系：结合操作行为、经济数据、社交关联构建检测模型；开放玩家举报入口，配套警告、禁赛、段位清零等梯度处罚，结合人工复核提升准确性。
封号处置机制精细化	玩家既支持封禁外挂账号，又担忧误封与处罚边界模糊；部分玩家尝试"降肝"类轻量化工具，被封号后倾向申诉，而对恶意外挂则要求公示与严惩。	构建"分级处罚+透明申诉"体系：区分作弊类型，轻量化作弊可通过保证金解封，恶意外挂永久封号并公示；搭建24小时智能申诉平台，支持证据上传与人工复核。
账号资产保护意识觉醒	游戏账号成为承载资金投入与情感价值的数字资产，价值持续攀升；黑产从卖挂转向撞库盗号、洗号、勒索，账号安全威胁从"公平破坏"转向"资产窃取"。	强化全链路资产防护：推广双因素认证、异地登录保护等措施；建立异常操作监测体系，实时预警并冻结风险账号；提供盗号找回、资产回溯服务，联动警方打击黑产。

游戏厂商视角

核心痛点：收入止损、品牌声誉、全球化合规、跨端统一治理。

从“事后救火”到“研发安全运营一体化”

过去，游戏安全多处于被动应对状态。往往在游戏上线后才发现外挂、破解等安全问题，再通过外部寻找解决方案抵御风险，全程陷入“事后补救”的“救火”循环。如今，提前规划安全防御成为行业共识。安全布局已前置到立项与研发阶段，在通信协议设计、关键逻辑校验、核心代码保护等环节，便引入安全团队或第三方安全保护系统。中大型厂商更搭建起专属安全中台，将反外挂能力标准化并嵌入上线全流程，大幅降低了游戏上线初期的安全风险。

游戏出海监管趋严，合规成为底线要求

过去，游戏出海面临复杂的全球法律环境，但部分厂商为控制成本，存在数据不符合“本地存储、不回流”要求的情况。当前，GDPR（欧盟）、CCPA（美国加州）等隐私法案的约束持续强化，要求厂商不仅要克制数据采集范围，更需将数据存储在本地。因此，出海游戏不再在“强力反挂”与“隐私合规”间冒险平衡，而是通过数据脱敏、采集最小化等方案收紧管控，业务数据与反外挂数据均存储于游戏运营地，从源头规避合规风险。

“内容安全”与“反外挂”并重，风控投入持续加大

过去，UGC、AIGC 内容的兴起让涉黄、涉政、暴恐等不良内容问题凸显，其对产品的破坏性不亚于外挂。但多数业务仅通过关键词过滤或限制 AI 能力等简单方式规避风险。现在，内容安全治理需求呈爆发式增长。运营方对即时语音检测、图片识别、文本过滤、AI 大模型内容治理等技术的依赖度显著提升，同时在安全预算分配中，内容风控的占比也在持续增加，形成“内容安全”与“反外挂”同等重要的治理格局。

外挂对抗从“阻断式打击”走向“柔性分类治理”

过去，应对破解、外挂作弊的手段较为单一，多采用封号、强制退出客户端等阻断式措施。这类方式虽直接，但对抗成本极高，难以形成长期治理效果。如今，外挂治理转向精细化分类施策的柔性模式。对于严重破坏游戏公平的作弊行为，除及时制止外，还会采用设备封禁、玩家身份验证等更隐蔽有效的措施；对于非紧急类作弊，则通过降低收益、弹出高难度验证等柔性方式引导规范。多样化的综合治理手段，相比单纯阻断式打击，更能实现长期有效的治理目标，同时降低对抗成本。

趋势维度	核心转变	过去模式	现在 / 未来模式	关键支撑点
治理链路	事后救火 ↓ 研发安全运营一体化	上线后被动应对外挂 / 破解，依赖外部“救火”	立项 + 研发阶段前置安全布局，安全能力标准化嵌入流程	通信协议设计 / 代码保护 中大型厂商安全中台
出海合规	成本优先 ↓ 合规为底线	数据未满足“本地存储”，规避监管风险	遵循 GDPR/CCPA，数据脱敏 + 采集最小化	全球隐私法案约束、运营地数据存储
风控重心	重反外挂 ↓ 内容安全 + 反外挂并重	仅靠关键词 / 限制 AI 规避不良内容	全场景内容治理需求爆发，预算占比提升	即时语音/图片 / 文本过滤，AI 大模型内容治理
对抗策略	阻断式打击 ↓ 柔性分类治理	高频使用封号 / 退客户端，对抗成本高	按危害分级施策，多手段长效治理	严重作弊：设备封禁 + 身份验证 轻度作弊：降低收益

——游戏安全四大核心趋势演变——

游戏服务商视角

核心痛点： 技术军备竞赛、硬件对抗难度大、权限限制和技术对抗的平衡。

防御手段 "AI 化"：以智能对抗智能

AI 技术催生的非侵入式作弊手段，极致模仿人类行为、隐蔽性极强，让传统反外挂技术难以应对。为此，"以 AI 反 AI" 成为核心防御思路，通过 AI 模型深度学习正常玩家操作轨迹，结合行为验证与 "玩家信用分系统" 实现玩家分层，对低信用玩家采用隔离匹配、功能限制等柔性措施替代简单封号，精准捕捉作弊痕迹的同时兼顾合规与玩家体验。

跨端融合加剧风险，多维度检测技术升级破局

移动端与 PC 端跨端体验普及，黑灰产借 CE 修改模拟器数据、模拟点击操控海量游戏实例等方式作弊，既提升外挂隐蔽性，更使黑产效率倍增。传统检测仅能识别运行环境，且无法一概禁止模拟器玩家，安全厂商需升级检测能力，融合行为检测、侧信道检测等多维度技术，精准区分正常跨端玩家与作弊行为，针对性打击黑灰产工作室，维护游戏健康生态。

权限约束下的攻防平衡：合规范围内挖掘数据价值

移动端与 PC 端跨端体验普及，黑灰产借 CE 修改模拟器数据、模拟点击操控海量游戏实例等方式作弊，既提升外挂隐蔽性，更使黑产效率倍增。传统检测仅能识别运行环境，且无法一概禁止模拟器玩家，安全厂商需升级检测能力，融合行为检测、侧信道检测等多维度技移动端隐私合规收紧、权限限制压缩，使游戏安全系统操作空间受限，形成 "防守方受限、攻击方无界" 的攻防不对等局面。安全厂商转向非侵入式检测创新，跳出传统特征识别与规则拦截框架，通过用户长期行为画像异常挖掘、设备环境可信状态多维度交叉验证、应用运行链路隐性数据轨迹分析等方式，在合规边界内最大化挖掘可用数据维度，实现权限约束下的高效风控。术，精准区分正常跨端玩家与作弊行为，针对性打击黑灰产工作室，维护游戏健康生态。

SaaS 化与标准化：安全能力从 "大厂独享" 到 "行业普惠"

独立游戏与中小型厂商缺乏专业安全团队，即便中大型厂商也难应对快速变异的新型作弊技术。SaaS 模式推动安全服务标准化普及，安全厂商将顶级反加速、防修改、反模拟器等能力封装为标准 API 与 SDK，厂商无需自建团队，接入即可获得顶尖外挂检测及黑灰产治理能力，同时享受持续检测更新、技术迭代与应急响应支持，实现 "接入即防护、持续享升级"，让核心安全技术从大厂专属变为行业普惠。

玩家社区

核心痛点： 游戏公平性、个人隐私焦虑、误封冤案、账号安全。

内核级反作弊的信任重构：移动端合规消解隐私顾虑

玩家对内核级反作弊程序的信任危机，核心源于对高权限程序过度采集隐私数据的担忧。这一顾虑在 Windows 时代尤为突出，当时数据采集限制宽松，部分反作弊程序的过度收集行为确实损害了玩家信任。但进入移动端时代后，手机系统的采集权限管控大幅收紧，叠加《个人信息保护法》等隐私合规政策的严格监管，反作弊程序需遵循 "正当、必要" 原则，仅调取设备信息、战斗日志等反作弊必需数据，且需通过脱敏、字段裁剪等技术实现最小化采集，几乎不存在过度收集风险，玩家隐私顾虑正逐步消解。

软作弊成新痛点，"菜" 与 "演" 的界定考验检测能力

相较于过往显性的 "暴力挂"，如今玩家更痛恨 "演员"（故意消极比赛）、代练、炸鱼、鼠标宏等隐蔽性强的软作弊行为。这类行为破坏匹配公平性和游戏体验，玩家对厂商治理 "消极比赛""扰乱匹配机制" 的诉求日益强烈。这对安全检测提出了更高要求 —— 如何通过经济数据、操作轨迹、社交互动等多模态数据综合判断，精准区分 "技术不佳" 与 "恶意演局"，已成为玩家投诉的重灾区，也是厂商提升风控精细化水平的关键方向。

封号处置的精细化诉求：明确边界、完善申诉与公示机制

玩家对封号处置的态度呈现双重性：既支持厂商封禁恶意外挂账号，又担忧存在误封、封号边界模糊等问题。部分玩家会尝试“降肝”“提升体验”类轻量化作弊工具，试探厂商检测与处罚尺度；若遭遇封号，多数玩家不会直接弃游，而是倾向通过申诉维权，甚至接受交纳保证金的解封方式。同时，玩家普遍期待厂商对恶意作弊账号进行封号公示，并积极参与举报监督，这要求厂商建立清晰的封号分级标准、高效的申诉通道与透明的公示机制，平衡处罚力度与玩家权益。

账号资产保护意识觉醒，安全重心转向数字资产防护

随着数字娱乐资产价值攀升，游戏账号已从单纯的登录凭证，转变为承载玩家资金投入与情感价值的重要数字资产。这一变化推动玩家安全意识升级，双因素认证、异地登录提醒、扫码登录等防护手段成为普遍习惯。与此同时，黑产作案方向从卖挂转向撞库盗号、洗号、登录态盗取变现等账号侵害行为，玩家对安全的需求也从“公平无挂的游戏环境”，延伸至“数字资产不被窃取”的核心诉求。构建坚固的账号安全防护体系，已成为维系玩家信任、保障用户留存的关键生命线。

安全问题类别	玩家核心诉求	厂商应对关键策略
内核级反作弊信任危机	1. 反作弊程序不过度采集隐私数据；2. 明确告知数据采集范围与用途；3. 保障个人信息安全无泄露风险。	1. 遵循“最小必要”原则，仅采集反作弊必需数据（如设备基础信息、战斗操作日志）；2. 数据处理采用脱敏、加密、本地计算等技术，避免原始信息暴露；3. 公示数据采集清单与使用说明，通过合规认证（如等保2.0）增强信任；4. 建立隐私问题反馈通道，及时响应玩家疑虑。
软作弊治理诉求升级	1. 彻底打击“演员”、代练、炸鱼、鼠标宏等软作弊；2. 精准区分“技术差”与“恶意演”，避免误判；3. 保障匹配机制公平，提升游戏体验。	1. 构建多维度检测模型：结合操作行为（点击频率、技能释放逻辑）、经济数据（胜率波动、击杀死亡比异常）、社交关联（组队异常互动）综合判定；2. 引入AI行为分析，通过对比同段位玩家操作基线，识别异常行为；3. 建立软作弊分级处罚机制（警告→禁赛→段位清零→封号），灵活适配违规程度；4. 开放玩家举报入口，结合人工复核提升判定准确性。
封号处置的边界与权益保障	1. 明确封号标准，避免误封；2. 提供高效申诉渠道与解封途径；3. 恶意外挂账号需公示处罚结果；4. 拥有参与举报监督的权利。	1. 制定分级处罚规则：区分“轻量化作弊”（如辅助降肝工具）与“恶意外挂”（如透视、自瞄），前者可采用保证金解封、功能限制，后者直接永久封号；2. 搭建智能申诉平台，支持玩家上传证据，结合人工审核缩短申诉周期（24小时内响应）；3. 建立封号公示机制，曝光恶意外挂账号信息（隐去隐私字段），接受玩家监督；4. 优化举报系统，对有效举报玩家给予积分、道具等奖励，激发参与热情。
账号资产安全防护	1. 保障账号不被盗窃、篡改、勒索；2. 拥有便捷的主动防护手段；3. 账号异常时能及时预警与止损。	1. 强化基础防护：强制开启双因素认证，默认触发异地登录验证、设备绑定提醒；2. 升级安全技术：采用人脸生物识别、动态令牌等高级验证方式，抵御撞库盗号；3. 建立异常监测体系：实时监控登录IP、交易行为、装备转移等异常操作，及时推送预警并冻结账号；4. 提供盗号止损服务：支持账号找回、资产回溯，联动警方打击盗号黑产。

——不同游戏安全问题应对策略——

闪易智企·易盾

04

游戏安全年度自检指南



自检指南概述

随着游戏产业的成熟，黑灰产技术也在高速迭代。游戏厂商需要一套标准化的安全自检流程（Security Self-Assessment），帮助项目组在研发阶段（SDLC）与运营阶段快速识别安全盲点，从而：

- 降低业务损失与运营成本
- 规避法律与合规风险
- 保障游戏公平性与营收安全

自检指南评价体系

为便于量化安全风险，本指南采用S-A-B-C 四级安全评估模型，并辅以红线项一票否决制。

等级	安全状态	定义描述	应对措施
S	极高安全水平	具备多层防御体系，通过红蓝对抗测试，有完善、可演练的应急响应机制。	保持持续监控，定期复盘与应急演练。
A	安全可控	核心功能已防护，已知漏洞修复完毕，满足当前合规要求。	可作为上线标准，需持续优化长尾风险。
B	风险预警	存在部分已知风险（如反外挂能力薄弱），但尚未触及核心营收或合规红线。	限期整改，可"带病"上线但必须加强监控与人工干预。
C	高危状态	存在严重逻辑漏洞、合规红线问题，或基本无安全防护（裸奔）。	禁止上线，立即熔断发布流程，优先投入资源整改。

红线项（一票否决）

以下任一问题存在，即判定整体安全等级为**C 级（高危）**，不得上线：

- 用户隐私泄露风险（违反法律合规要求）
- 可实现无限刷充值 / 道具等严重经济漏洞
- 容易导致服务器大面积宕机的明显缺陷

自检指南

1. 合规风险 (Compliance Risk)

核心关注：数据隐私、未成年人保护、实名认证

隐私政策合规

检查游戏是否在用户明确同意隐私协议之前，就开始采集 MAC、IMEI、OAID 等设备信息。

红线要求：严禁在用户同意前采集任何可识别个人信息，一旦发现视为一票否决项。

检查首次启动时是否清晰展示隐私政策，并记录用户的同意行为，例如：同意版本、时间、用户 ID 等。

建议保存可追溯审计记录，以便应对监管抽查或用户投诉。

最小化采集原则

检查是否申请了与游戏核心功能无关的敏感权限，例如通讯录、短信、非必要的地理位置等。

对"仅用于推荐优化或统计分析"的权限，需要评估其是否真正必要。

检查是否存在"为了埋点/统计方便"而超范围采集用户数据的情况。

建议维护一份"权限与数据采集清单"，并经过法务 / 合规团队审核。

实名认证与防沉迷

检查游戏是否已经接入国家统一实名认证系统，或所在地区要求的合规实名方案。

涉及未成年人业务时，这通常属于强制性要求。

检查防沉迷机制是否可以通过断网、修改本地时间、修改时区等方式绕过。

建议防沉迷逻辑以服务端时间和服务端校验为准，避免单纯依赖客户端时间。

数据跨境传输与存储

如果游戏面向多个国家 / 地区运营，检查是否符合当地法律（如欧盟的 GDPR、中国的 PIPL）对数据本地化、跨境传输的要求。

如涉及跨境传输，应有合规评估和必要备案。

检查跨境访问相关的接口和管理后台，是否配置了严格的访问控制和审计日志，确保内部访问也可被追踪和追责。

第三方 SDK 合规性

检查集成的第三方 SDK（广告、统计、支付、登录等）是否存在已被披露的违规采集或越权行为。

建议建立 SDK 白名单，收集供应商的合规承诺与评估报告。

检查是否有定期审计与升级第三方 SDK 的机制，确保老版本 SDK 不因历史问题引入新的合规风险。

2. 破解风险 (Cracking Risk)

核心关注：客户端完整性、资源盗用、二次打包

代码混淆与加固

- 检查是否已对游戏核心逻辑（例如战斗结算、经济结算、反作弊逻辑等）做代码混淆和加固处理。建议使用成熟的加固或 VMP 等方案，并对关键逻辑做重点保护。
- 检查关键算法、校验逻辑是否尽量放在 Native 层（so / dll 等），而不是易被修改的 Java / C# 层。

目的在于提高逆向分析和篡改的难度。

完整性校验（Signature / Hash Check）

- 检查客户端启动时是否对签名（Signature）进行校验，防止被二次打包或篡改后继续使用。
- 检查是否对关键 DEX / DLL / so 文件进行 Hash 校验，防止被替换或注入恶意代码。
- 检查完整性校验逻辑是否放在 Native 层，并具备一定的混淆 / 反调试手段，而不是只在业务层简单判断。

反调试与反注入

- 检查是否有检测常见调试 / 注入框架的机制，例如 ptrace、frida-server、Xposed、Magisk 等。
- 检查发现调试 / 注入行为后的处理策略：

资源加密与防盗用

- 检查核心美术资源（如 AB 包、模型、特效、音频）是否经过加密或压缩混淆，避免被轻易解包提取。
- 检查配置表（Lua / Excel / Json 等）是否进行了加密或简单混淆，避免被直接读取并用于外挂 / 私服。
- 检查资源加载流程中是否有版本校验或签名校验，防止资源被替换注入恶意内容。

3. 外挂风险 (Cheating Risk)

核心关注：内存修改、加速器、模拟点击、脚本、定制挂

内存修改检测

- 检查是否针对常见内存修改器（如 GameGuardian、Cheat Engine 等）做特征检测或进程扫描。
- 检查关键数值（如血量、金币、钻石、经验、移动速度等）在客户端是否进行了加密存储或混淆处理，例如：

使用异或、分段存储、随机偏移等方式，而不是以明文整数形式保存在固定地址。

变速齿轮 / 加速器检测

- 检查游戏是否过度依赖客户端时间来驱动关键逻辑（如冷却、资源产出、体力恢复等）。
- 建议关键逻辑均以服务器时间为准。
- 检查是否对时间相关行为做多重校验，例如：

结合服务器时间戳、客户端多源时间（系统时间、CPU 时间、帧时间等），检测异常加速 / 减速行为。

模拟点击与脚本行为

- 检查是否具备识别常见脚本工具的能力，如触控精灵、按键精灵、按键录制工具等（包括窗口类名、进程特征等）。
- 检查是否对操作行为做模式识别，例如：极其稳定的点击间隔、超长在线但无视野变化、反应速度明显超出人类极限等。
- 检查是否对云手机、模拟器、虚拟机环境进行检测，如常见的 VMOS、光速虚拟机、各家云手机厂商环境。

必要时在虚拟环境中限制匹配段位、限制经济收益。

4. 私服风险 (Private Server Risk)

核心关注：服务端代码泄露、协议破解、模拟服

通信协议安全

- 检查客户端与服务器之间的数据传输是否全程加密，避免明文协议被直接抓包和重放。
- 建议使用 HTTPS / TLS 或自定义加密层，避免关键字段明文流转。
- 检查是否对请求包设计了序列号、时间戳、随机数等机制，防止简单的重放攻击（Replay Attack）生效。
- 检查协议结构中是否避免将敏感逻辑放到客户端（例如客户端决定最终扣费 /发奖结果），重要结算需放在服务端。

服务端二进制与源码保护

- 检查服务端程序是否有基本防泄漏策略，例如：
- 部署时绑定机器码或环境特征、限制运行环境、限制可执行文件外泄价值。
- 检查内部权限管理是否严格：
- 源码仓库访问是否按角色精细划分、是否有离职账号即时收回机制、是否有代码导出审计。
- 检查是否对生产环境配置（数据库账号、密钥、证书等）做加密和访问控制，避免一旦配置泄露，私服可以轻易接入。

协议文档与调试工具管理

- 检查内部是否存在未受控的协议文档、抓包脚本、调试工具在外部分发的风险。
- 对外包团队、合作方、测试渠道等，需明确协议和文档保密要求，并在合同层面约束。

5. 漏洞风险 (Vulnerability Risk)

核心关注：逻辑漏洞、刷物品、宕机、Web漏洞

业务逻辑漏洞（Business Logic）

- 并发场景检查：

测试同一账号在多设备同时登录、或对同一接口进行高并发请求时，是否会出现刷物品、重复发奖、货币异常增加等情况。

- 边界值测试：

对购买数量、充值金额、次数等相关字段进行 0、负数、极大值（接近 / 超过整型上限）测试，检查是否存在溢出导致的异常收益或服务器错误。

- 检查关键操作（如交易、赠送、合成）在异常中断（断网、闪退）情况下，是否会重复结算或漏结算。

协议模糊测试（Fuzzing）

- 检查是否对重要接口做过模糊测试（Fuzzing），向服务器发送畸形、超长、缺字段、非法类型的数据包，观察服务器是否会崩溃、异常占用资源或出现安全异常。
- 检查异常数据是否有统一的校验和错误处理逻辑，避免出现未捕获异常导致服务进程崩溃（DoS 风险）。

充值与游戏经济系统

- 检查充值订单的校验流程：
- 后端是否严格验证金额、商品 ID、订单来源渠道和订单状态，而不是简单依赖客户端传入结果。
- 检查是否存在"前端修改显示金额 / 商品后，后端未再校验"的情况；
- 一旦存在，可导致低价购买高价值商品或直接免费获得付费内容。
- 检查游戏内货币与道具的产出 / 消耗是否有异常监控与风控策略，对异常行为及时预警和封禁。

Web 与运营配套系统

- 检查官网、充值页、活动页、GM 后台等 Web 系统是否做过基础安全测试（如 SQL 注入、XSS、越权访问等）。
- 检查运营后台权限是否分级，是否存在"普通运营账号即可直接发放大量货币 / 道具"的高危设计。

6. 内容风险 (Content Risk)

核心关注：涉政涉黄、辱骂引战、广告拉人、UGC合规

玩家聊天与社交内容

- 检查游戏内聊天、私信、公屏、语音频道等是否有敏感词过滤机制，覆盖涉政、涉黄、暴恐、赌博、诈骗等关键词。
- 检查是否有玩家举报通道，以及客服 / 运营审核和处理流程，对恶意辱骂、引战、骚扰行为是否有禁言 / 封号策略。

公会、昵称、签名与个性化展示

- 检查玩家昵称、公会名、公会公告、个人签名、空间动态等自定义内容，是否经过审核或敏感词过滤。
- 检查是否支持对违规昵称、公会等进行运营后台快速处理（改名、解散、禁用等），并记录操作审计。

UGC 内容与地图编辑器等

- 对玩家自制关卡、地图、皮肤、评论、帖子等 UGC 内容，检查是否有人工 / 机器结合的内容审核机制。
- 检查是否有"先审后发"或"先发后审 + 快速下架"策略，以应对违规内容扩散。
- 检查是否对 UGC 上传（图片、音频、文本等）做了格式与大小限制，并防止恶意脚本或违法内容通过 UGC 渠道传播。

外部引流与广告内容

- 检查游戏内是否存在玩家发布 QQ 群、微信群、非法网站、代练 / 代充广告、博彩链接等行为的治理机制。
- 检查是否对公告位、Banner、激励视频等投放内容进行审核，避免出现违规广告或误导性宣传，从而引发监管风险。

05

安全大事记



结合你此前关注的国内游戏安全事件，补充全球范围内的黑客攻击、平台监管、未成年人保护等相关安全大事后，以下是2025年1 - 11月完整的全球游戏安全大事记：

1月 波兰游戏工作室遭勒索软件攻击

1月27日，波兰游戏开发商Big Cheese Studio遭遇网络攻击，黑客侵入其游戏代码系统并获取员工个人信息，随后索要10万兹罗提（约合1.9万英镑）加密货币作为赎金，否则就公开窃取的数据。攻击发生后该公司官网数小时内持续处于下线状态，其作为华沙证券交易所上市企业，此次事件也引发了游戏行业对数据安全的广泛担忧。

2月 Steam平台《PirateFi》植入恶意软件遭下架

2月6日上线Steam的免费生存游戏《PirateFi》，于2月12日被紧急下架。经核查，该游戏暗藏Vidar信息窃取恶意软件，会盗取玩家浏览器登录凭据、加密货币钱包等核心机密信息。V社紧急提醒玩家需重新安装Windows系统以彻底清除风险，推测当时约1500名玩家下载过该游戏。

3月 Steam《No Mercy》因不良内容遭多国围剿，《Sniper: Phantom's Resolution》涉恶意软件下架

3月22日上线的Steam成人视觉小说《No Mercy》，将针对女性的暴力与支配行为设为游戏目标，引发全球舆论谴责。4月英国技术大臣公开要求平台下架该游戏，澳大利亚监管机构也约谈平台，加拿大地区更是迅速下架该游戏；另一方

4月 米哈游协助破获两起跨国账号非法租售大案

当月米哈游对外披露，其协助中国江苏扬州警方打掉一个跨境游戏账号非法租售工作室，抓获25名涉案人员，查获近千万条公民个人信息，涉案流水近1亿元；同时协助湖南岳阳警方抓获另一跨省、跨境作案的账号非法租售团伙21人，查获60余万条被盗公民信息，涉案人员因涉嫌侵犯公民个人信息罪被依法处理。

5月 美国13岁少女因《Roblox》遭诱骗绑架，上海警方侦破《原神》外挂案

5月24日，美国艾奥瓦州一名13岁少女在《Roblox》平台被伪装成青少年的37岁男子诱骗后绑架、侵犯并跨州贩运。受害家庭起诉平台安全措施缺位，且有律师称其代表超400名类似受害者维权；此外，中国上海警方侦破《原神》"大世界消除"外挂案，抓获3名核心嫌疑人，该外挂曾导致超2万名玩家游戏角色异常、物品丢失。

6月 Unity引擎曝高危漏洞，波及全球多款知名游戏

本月，代号为CVE - 2025 - 59489的Unity引擎高危漏洞被曝光。该漏洞自2017年起便存在，影响2017.1及后续版本开发的所有游戏，黑客可利用其执行恶意代码、窃取用户信息。当时虽未发现漏洞被实际利用，但全球多家游戏开发商紧急启动风险排查。

7月 《BlockBlasters》上线Steam，暗藏恶意程序后门

7月31日，2D像素风格游戏《BlockBlasters》登陆Steam，初期通过刷大量正面评价获取玩家信任。黑客为规避平台审核，上线初期未植入恶意代码，而是计划通过后续更新部署攻击组件，为后续的恶意攻击做足准备。同月，《Roblox》平台为应对未成年人安全危机，推出"信任连线"社交功能及AI年龄估算技术，但被外界批评"为时已晚"。

8月 《BlockBlasters》推送恶意补丁窃取用户信息

8月30日，《BlockBlasters》发布Build19799326版本补丁，其中暗藏StealC信息窃取木马。该补丁会先探测玩家设备防护环境，若仅依赖Windows Defender，则释放恶意载荷，盗取Steam账号、加密货币钱包、浏览器数据等信息。一名拉脱维亚游戏主播试玩后，其Twitch账户中3.2万美元癌症治疗资金遭盗取。

9月 《BlockBlasters》恶意行为被曝光

安全机构G DATA公开披露《BlockBlasters》的恶意攻击机制，引发全球玩家对游戏补丁安全的警惕。

10月 Unity漏洞触发全球游戏紧急更新，《BlockBlasters》被下架

10月4日，Unity官方发布漏洞修复补丁，微软随即确认《炉石传说》《辐射：避难所》《星空》配套应用等多款全球热门游戏受漏洞影响，相关游戏紧急推送更新；同日，作恶多端的《BlockBlasters》被Steam全网下架，其关联的远程控制服务器也被安全团队逐步封禁。

11月 《使命召唤》系列公布全球反不良行为成果

11月13日，动视发布《使命召唤》系列玩家安全报告。数据显示，自2025年以来，该系列针对冒犯性语音、文字聊天等不良行为已采取超1600万次处罚措施。其中《黑色行动6》重复违规率下降43%，《使命召唤：战争地带》下降38%。同时，游戏宣布将在澳大利亚、新西兰上线主动语音监管功能，并新增意大利语语音监管支持，进一步完善全球多地区、多语言的安全监管体系。

12月 育碧《彩虹六号：围攻》遭遇史诗级黑客攻击

育碧旗下战术射击游戏《彩虹六号：围攻》遭遇多黑客团体协同攻击，是育碧近年最严重的游戏服务安全事件；12 月 22–28 日《命运方舟》封禁 10 个工作室账号、7 台设备，追缴 145 万金币，拦截异常交易 2569 笔。

支持单位

关于网易智企·易盾

网易智企·易盾是大模型时代数字内容风控领军者。

依托网易20多年的安全技术沉淀，提供数字内容安全、业务安全及应用安全全链路能力，致力于通过前沿AI技术帮助企业构建智能化风控体系，降低合规成本，保障业务健康增长。

目前，易盾已成为国内大模型平台的首选安全合作伙伴大模型平台企业覆盖率超90%，同时服务数千家娱乐社交、游戏、金融、媒体等各行业头部企业，间接守护99%以上网民的网络体验。

网易智企·易盾